



RELATÓRIO INDIVIDUAL PRELIMINAR

CGE - Controladoria Geral do Estado do Rio de Janeiro

1. Introdução

Este relatório apresenta os resultados preliminares da organização **CGE** relativos à Fiscalização TCE-RJ nº 18/2026, realizada pelo TCE-RJ entre fevereiro e junho de 2026 para avaliar o grau de adoção de práticas de governança e gestão de tecnologia da informação e comunicação pelas organizações jurisdicionadas.

O trabalho abrangeu órgãos e entidades de todos os poderes da Administração Pública Estadual e um conjunto de prefeituras municipais.

2. iGovTI 2026

A avaliação das organizações jurisdicionadas baseia-se no método de autoavaliação de controles (*Control Self-Assessment* – CSA), operacionalizado mediante questionário eletrônico. A ferramenta permitiu aos gestores declarar o nível de adoção das práticas de tecnologia da informação avaliadas e encaminhar a documentação probatória correspondente. As evidências anexadas e as justificativas apresentadas foram submetidas à análise de consistência por esta Equipe de Auditoria, servindo de subsídio para eventuais ajustes na pontuação declarada e para a identificação de inconformidades ou achados de auditoria.

O questionário do iGovTI 2026 foi estruturado com o objetivo de diagnosticar aspectos essenciais de governança e gestão de TIC, abrangendo segurança da informação, gestão de riscos, continuidade de negócios, serviços de tecnologia, contratações de TIC, estrutura e força de trabalho, desenvolvimento de soluções, gestão de projetos e temas emergentes, a exemplo do uso de inteligência artificial. Para além do diagnóstico situacional de cada organização, o instrumento serve como referencial metodológico para futuras ações de melhoria de gestão.

O iGovTI 2026 constitui um índice composto, mensurado em uma escala de 0 a 1. A quantificação do índice inicia-se com a conversão das respostas categóricas declaradas em coeficientes numéricos, conforme os critérios de valoração estabelecidos na Tabela 1.

Tabela 1 - Critérios de valoração das respostas qualitativas do questionário iGovTI 2026

Categoria de Resposta Declarada	Coefficiente Numérico
Não adota	0,00
Há decisão formal ou plano aprovado para adotá-lo	0,05
Adota em menor parte	0,15
Adota parcialmente	0,50

Categoria de Resposta Declarada	Coefficiente Numérico
Adota em maior parte ou totalmente	1,00

(Fonte: elaboração própria)

Nas questões que admitem itens de detalhamento, a pontuação da questão principal sofre deduções proporcionais à quantidade de itens não atendidos pela organização. Subsequentemente, os valores são consolidados por meio de agregação ponderada em uma estrutura hierárquica. O índice final é composto por dois blocos principais, conforme detalhado na Figura 1: **Governança de TIC (peso de 47,8%)**, formado por 4 questões de agregação direta; **Gestão de TIC (iGestTI) (peso de 52,2%)**, estruturado em 6 dimensões operacionais que consolidam 20 questões principais ponderadas.

Figura 1 - Composição do iGovTI 2026



(Fonte: elaboração própria)

Com base na pontuação consolidada do iGovTI 2026, a organização é classificada em um de quatro níveis de maturidade, cujos intervalos de pontuação estão definidos na Tabela 2 e representados graficamente na parte inferior da Figura 1.

Tabela 2 - Intervalos de pontuação para enquadramento nos níveis de maturidade

Nível de Maturidade	Intervalo do Índice (iGovTI)
Inexpressivo	$0,00 \leq \text{iGovTI} < 0,15$
Iniciando	$0,15 \leq \text{iGovTI} < 0,40$

Nível de Maturidade	Intervalo do Índice (iGovTI)
Intermediário	$0,40 \leq \text{iGovTI} < 0,70$
Aprimorado	$0,70 \leq \text{iGovTI} \leq 1,00$

(Fonte: elaboração própria)

2.1. Cenário Geral

A análise consolidada apresentada nesta seção fundamenta-se nos resultados calculados para as 114 organizações que integram o universo amostral da fiscalização. A análise visa contextualizar o resultado individual da organização **CGE**, identificar padrões de maturidade, assimetrias entre governança e gestão e capacidades desenvolvidas no conjunto avaliado.

A distribuição por nível de maturidade, apresentada na Figura 2, evidencia concentração nos estágios iniciais. Das 114 organizações, 61 (53,5%) foram classificadas no nível **Inexpressivo** e 39 (34,2%) no nível **Iniciando**. Assim, 100 organizações (87,7%) obtiveram resultado inferior a 0,40. Somente 10 organizações (8,8%) alcançaram o nível **Intermediário** e 4 (3,5%) o nível **Aprimorado**.

Figura 2 - Distribuição das organizações por nível de maturidade do iGovTI 2026



(Fonte: elaboração própria)

O iGovTI apresentou média de 0,187 e mediana de 0,135. O primeiro quartil foi 0,066 e o terceiro quartil, 0,235, o que evidencia a concentração de 50% das organizações avaliadas nesse intervalo, bem como a permanência de pelo menos 75% das entidades

abaixo do nível Intermediário. A divergência positiva entre a média e a mediana, combinada com o valor máximo de 0,777 e com apenas 4 organizações no nível Aprimorado, caracteriza uma distribuição com assimetria à direita (positiva): um grupo reduzido de resultados elevados desloca a média para cima, sem alterar o quadro predominante de baixa maturidade. 5 organizações apresentaram valor igual a zero no índice calculado.

A distribuição contínua da Figura 3 complementa a classificação por faixas e permite observar a concentração dos resultados, os limites de maturidade e a distância entre a mediana e os valores mais elevados.

Figura 3 - Distribuição contínua dos resultados do iGovTI 2026



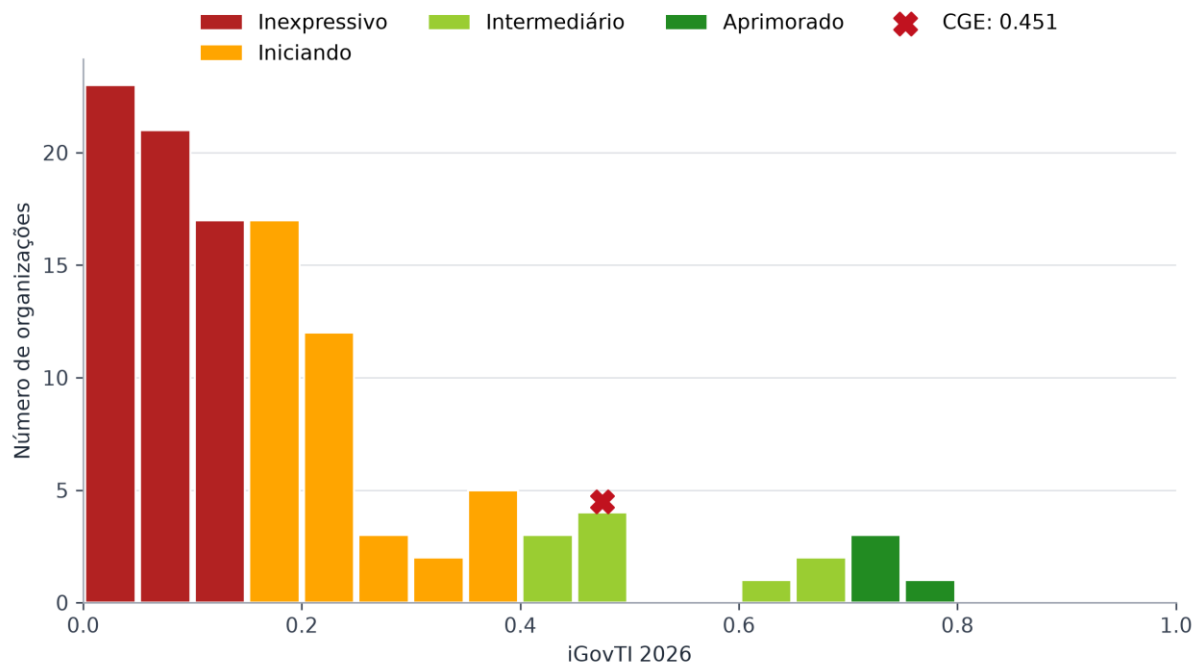
(Fonte: elaboração própria)

A posição específica da organização **CGE** nessa distribuição pode ser observada na Figura 4. Diferenças marginais de pontuação entre organizações adjacentes no ranking devem ser interpretadas com cautela analítica, visto que o modelo matemático de composição do índice não pressupõe estimativa de erro amostral e que os resultados estão sujeitos à qualidade e à fidedignidade declaratória do jurisdicionado.

2.2. Cenário atual - CGE

Apresentado o panorama geral do universo fiscalizado, esta subseção detalha o desempenho específico da organização jurisdicionada. A organização **CGE** obteve o **valor 0,4514 para o iGovTI 2026**, correspondente ao nível **Intermediário** de maturidade.

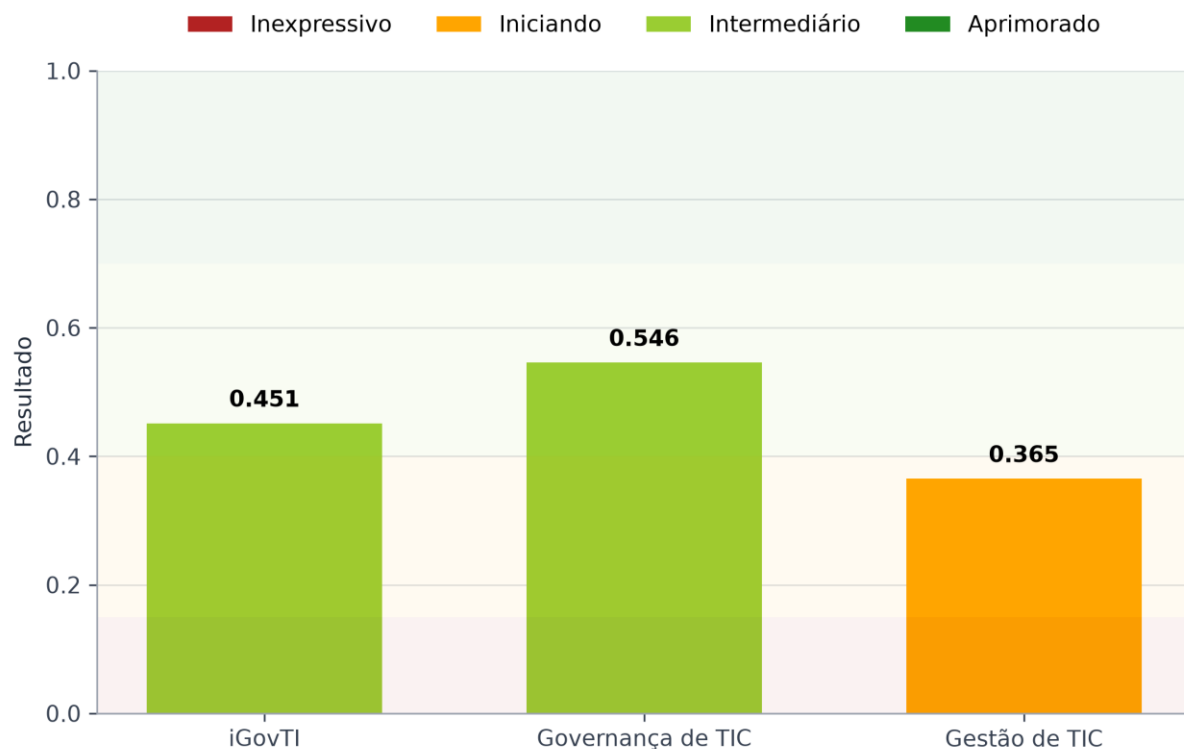
Figura 4 - Distribuição dos resultados do iGovTI 2026 e posição da organização CGE



(Fonte: elaboração própria)

A Figura 5 apresenta a composição do resultado da organização **CGE** entre governança e gestão de TIC.

Figura 5 - Resultado da organização CGE por componentes do iGovTI 2026



(Fonte: elaboração própria)

Tabela 3 - Resultado sintético do iGovTI 2026 da organização CGE

Componente	Peso no iGovTI 2026	Valor
Governança de TIC	0,4777	0,5459
Gestão de TIC	0,5223	0,3650
iGovTI 2026	1,0000	0,4514

(Fonte: elaboração própria)

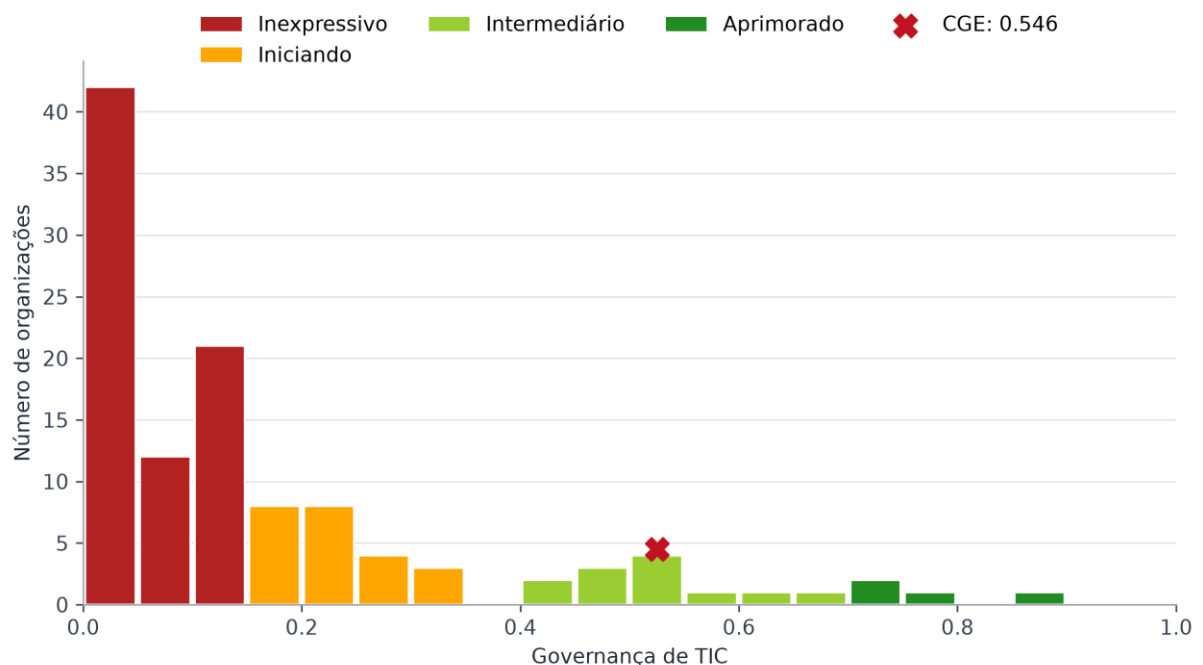
2.2.1. Governança de TIC

A governança de TIC avalia a capacidade da alta administração de orientar, dirigir, monitorar e controlar o uso da tecnologia da informação, de modo alinhado aos objetivos institucionais, aos riscos relevantes e às necessidades das áreas finalísticas e administrativas.

No iGovTI 2026, a dimensão de governança consolida práticas relacionadas ao modelo de gestão de TIC, à atuação de comitês ou instâncias equivalentes, no monitoramento do desempenho, à participação da alta administração e ao alinhamento entre decisões de TIC, estratégia organizacional, orçamento, riscos e valor público.

A organização **CGE** obteve o **valor 0,5459** no componente **Governança de TIC**.

Figura 6 - Resultado do componente Governança de TIC da organização CGE



(Fonte: elaboração própria)

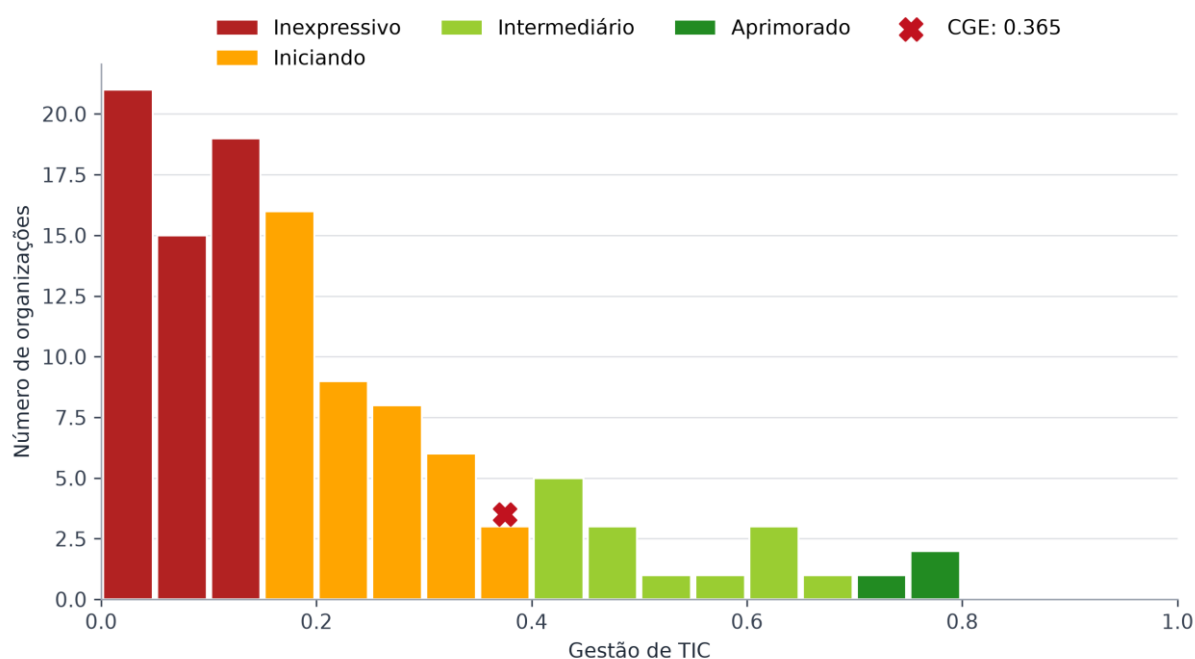
2.2.2. Gestão de TIC

A gestão de TIC avalia a capacidade da organização de planejar, executar, monitorar e aperfeiçoar processos, serviços, controles, recursos e contratações de tecnologia da informação, de forma compatível com suas necessidades institucionais.

No iGovTI 2026, o componente **Gestão de TIC (iGestTI)** consolida seis dimensões operacionais: planejamento de TIC, gestão de serviços de TIC, gestão de riscos de TI e segurança da informação, estrutura de segurança da informação, processos de segurança da informação e gestão de soluções de TIC.

A organização **CGE** obteve o **valor 0,3650 no componente Gestão de TIC**.

Figura 7 - Resultado do componente Gestão de TIC da organização CGE



(Fonte: elaboração própria)

2.3. Relação entre governança e gestão de TIC

Os indicadores descritivos da Tabela 4 mostram que o componente de gestão apresentou resultados superiores aos de governança no conjunto avaliado. A média da Gestão de TIC foi 0,208, ante 0,164 para Governança de TIC; as medianas foram, respectivamente, 0,153 e 0,117. As duas médias situaram-se no nível Iniciando, enquanto a mediana de Governança de TIC permaneceu no limite superior do nível Inexpressivo e a mediana de Gestão de TIC, no nível Iniciando.

Tabela 4 - Estatísticas descritivas do iGovTI 2026 e de seus componentes principais

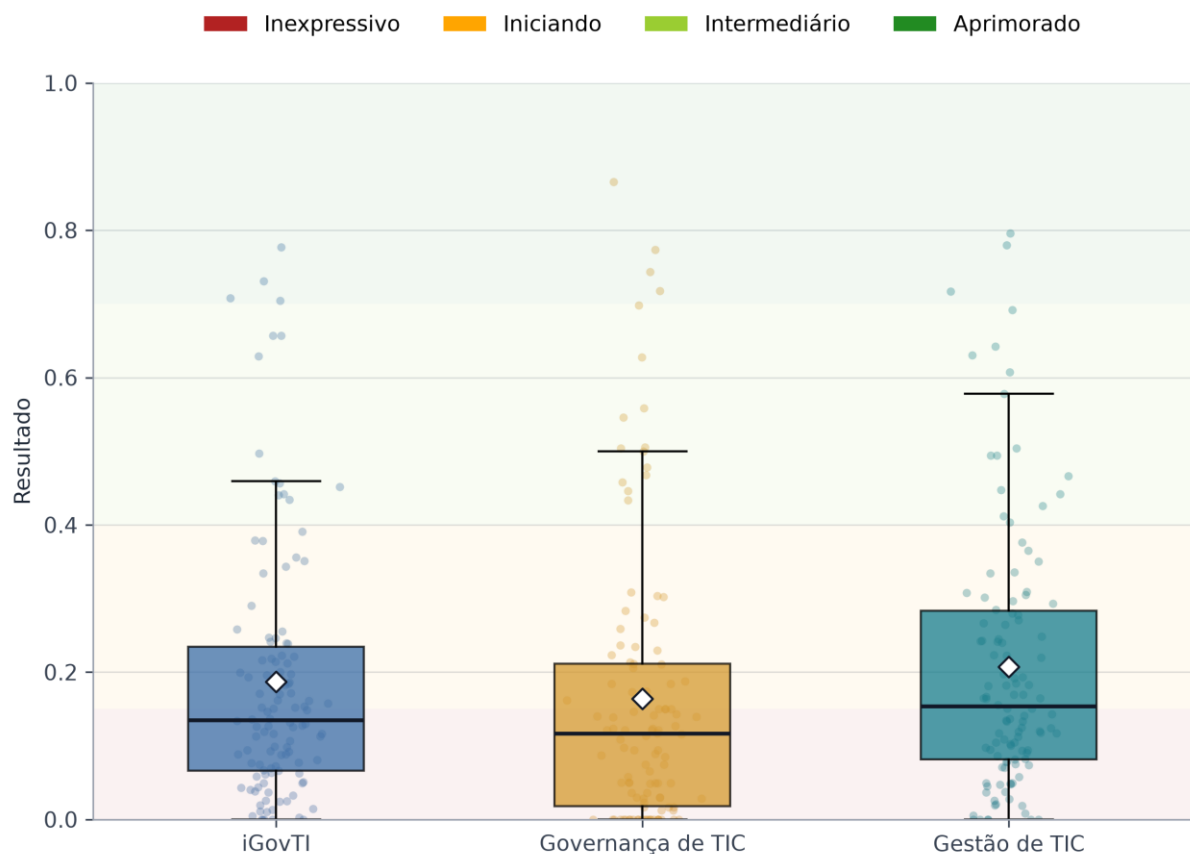
Indicador	Média	1º quartil	Mediana	3º quartil	Organizações com valor >= 0,40	Valor CGE
-----------	-------	------------	---------	------------	--------------------------------	-----------

Indicador	Média	1º quartil	Mediana	3º quartil	Organizações com valor >= 0,40	Valor CGE
iGovTI	0,187	0,066	0,135	0,235	14 (12,3%)	0,4514
Governança de TIC	0,164	0,018	0,117	0,211	16 (14,0%)	0,5459
Gestão de TIC	0,208	0,082	0,153	0,283	17 (14,9%)	0,3650

(Fonte: elaboração própria)

A Figura 8 permite comparar a dispersão dos três indicadores. O resultado em Gestão de TIC superou o de Governança de TIC em 76 organizações (66,7%); o movimento inverso ocorreu em 33 (28,9%); e houve igualdade em 5 (4,4%). O padrão indica que, para a maior parte das organizações, as capacidades operacionais de gestão se situaram em patamar superior ao dos mecanismos de direção, monitoramento e controle exercidos pela alta administração. Essa diferença, contudo, não elimina a baixa maturidade da gestão: 97 organizações (85,1%) também obtiveram resultado em Gestão de TIC inferior a 0,40.

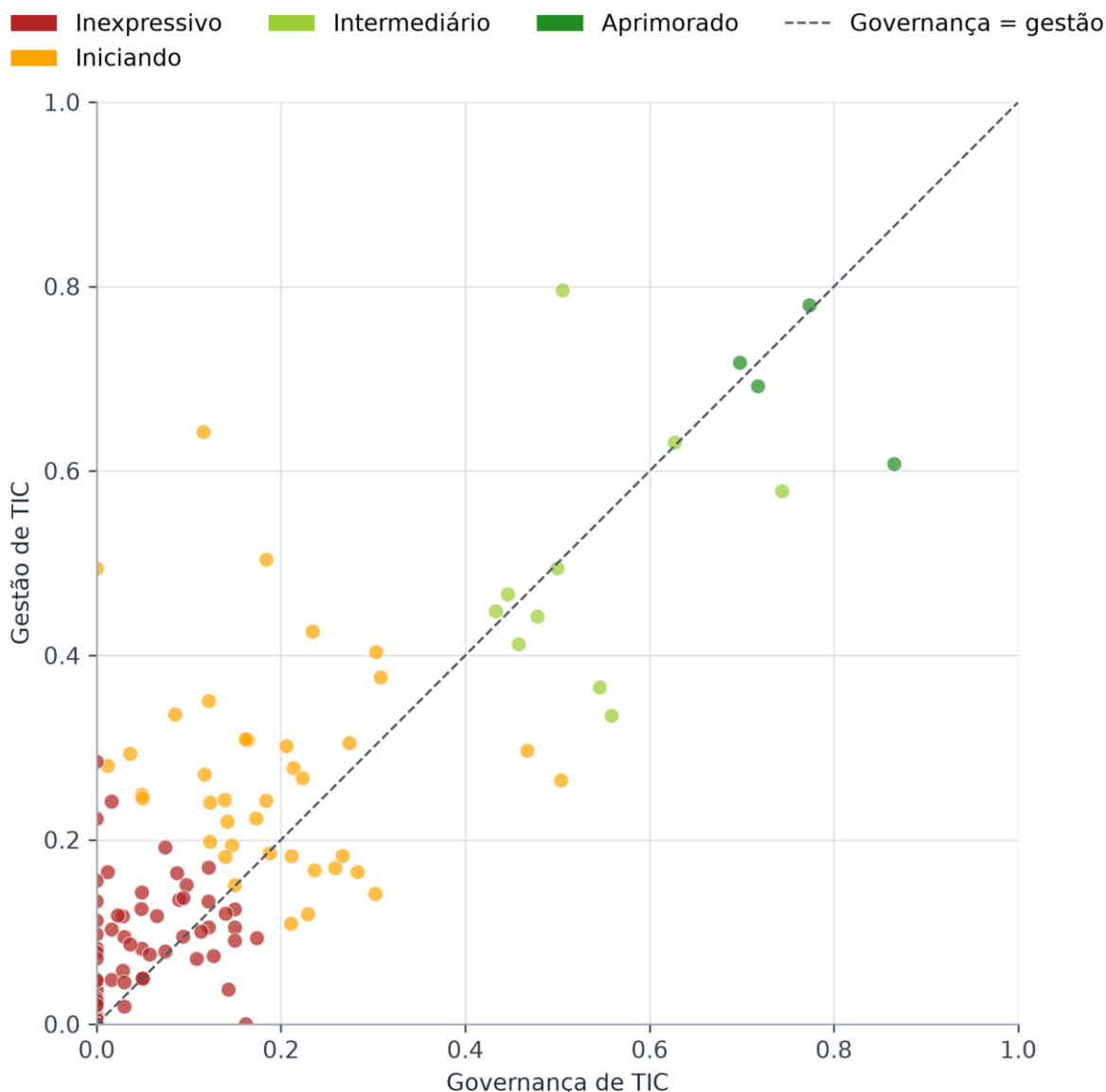
Figura 8 - Distribuição do iGovTI 2026 e dos componentes Governança de TIC e Gestão de TIC



(Fonte: elaboração própria)

A Figura 9 mostra a posição simultânea das organizações nos dois componentes. Pontos abaixo da diagonal representam resultado de gestão superior ao de governança; pontos acima da diagonal representam a situação inversa.

Figura 9 - Relação entre os resultados de governança e gestão de TIC



(Fonte: elaboração própria)

No caso da organização **CGE**, o resultado em Gestão de TIC ficou abaixo do resultado em Governança de TIC. Esse perfil indica oportunidade de fortalecer a transformação das diretrizes de governança em processos, controles, serviços, capacidades operacionais e práticas de gestão de TIC. A leitura deve ser aprofundada à luz das evidências e dos achados correspondentes.

2.4. Dimensões da gestão de TIC

A decomposição da Gestão de TIC revela diferenças relevantes entre as seis dimensões avaliadas. Conforme a Tabela 5, **Planejamento de TIC** apresentou a maior média (0,293) e a maior mediana (0,157). A dimensão com maior média também figurou

como a de maior resultado em 50 organizações (43,9%), considerados os empates. Esse padrão indica que algumas capacidades se encontram mais disseminadas do que outras no conjunto fiscalizado.

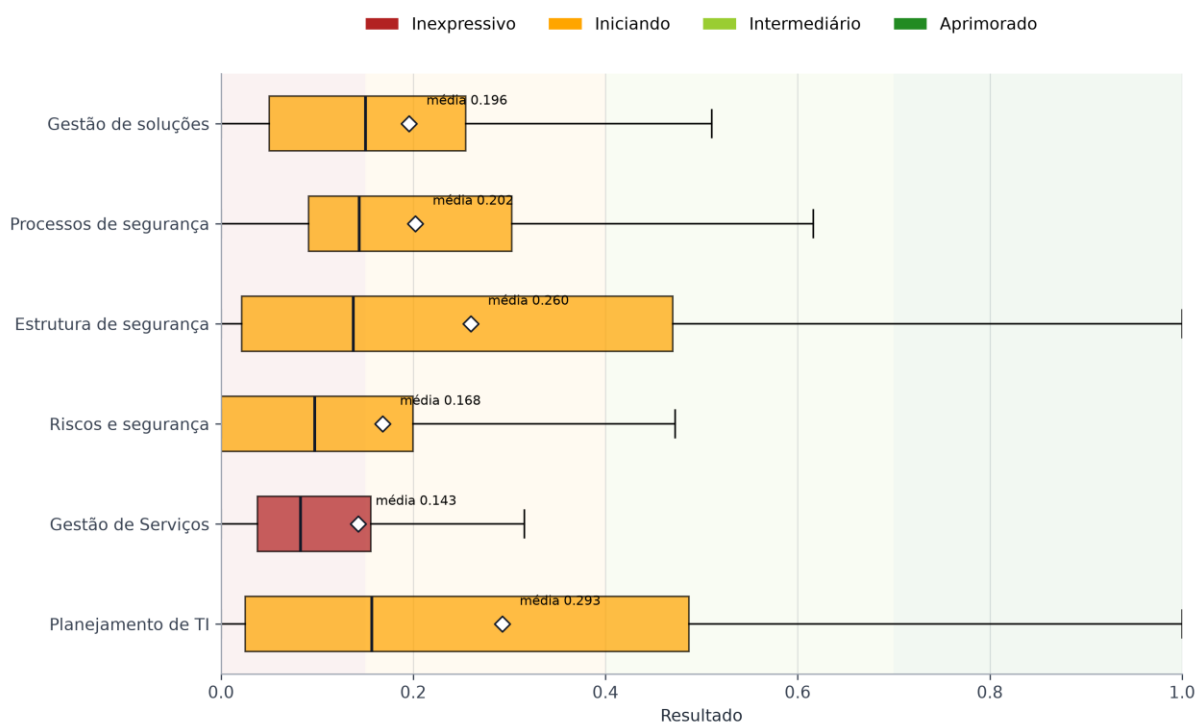
Tabela 5 - Estatísticas descritivas das dimensões de Gestão de TIC

Dimensão	Média	Mediana	Resultados iguais a zero	Organizações com valor inferior a 0,40	Valor CGE
Planejamento de TIC	0,293	0,157	21 (18,4%)	80 (70,2%)	0,8933
Gestão de Serviços de TIC	0,143	0,083	20 (17,5%)	102 (89,5%)	0,1938
Gestão de Riscos de TI e Segurança da Informação	0,168	0,097	32 (28,1%)	97 (85,1%)	0,0500
Estrutura de Segurança da Informação	0,260	0,137	25 (21,9%)	83 (72,8%)	0,6444
Processos de Segurança da Informação	0,202	0,144	10 (8,8%)	95 (83,3%)	0,1577
Gestão de Soluções de TIC	0,196	0,150	26 (22,8%)	101 (88,6%)	0,3382

(Fonte: elaboração própria)

A distribuição completa das seis dimensões é apresentada na Figura 10, incluindo medianas, intervalos interquartis e médias.

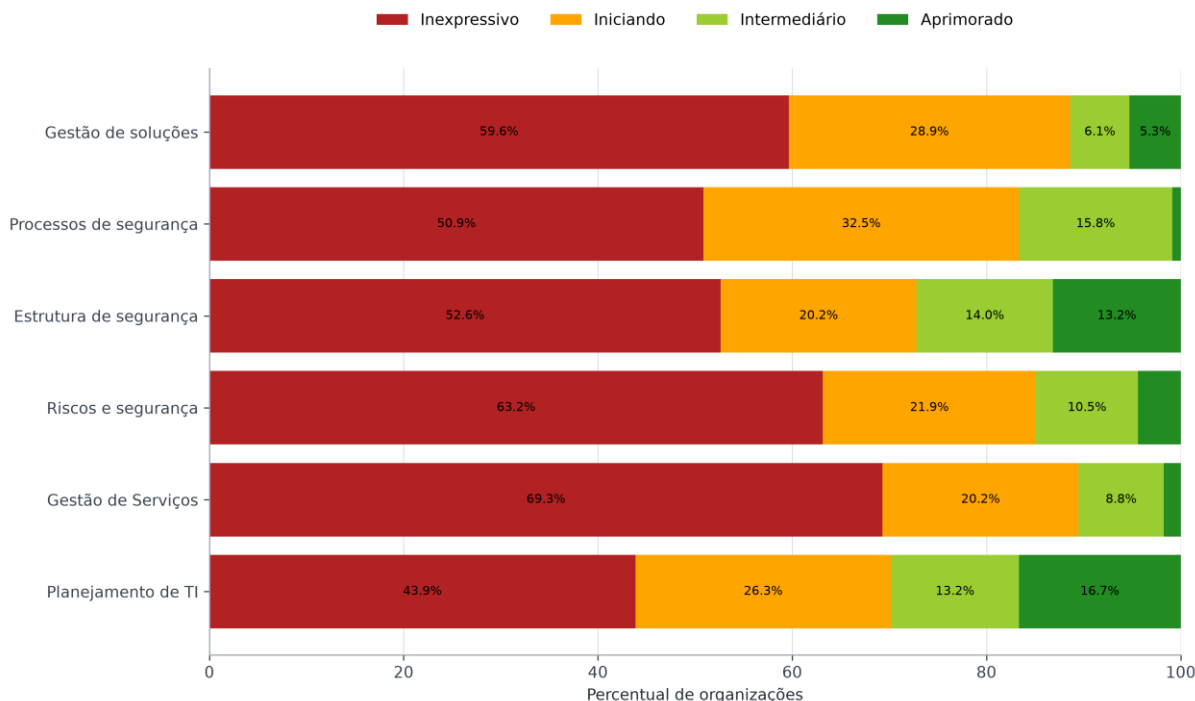
Figura 10 - Distribuição dos resultados das seis dimensões de Gestão de TIC



(Fonte: elaboração própria)

A Figura 11 explicita a composição de cada dimensão por nível de maturidade e permite verificar em quais capacidades se concentram as organizações nos estágios iniciais.

Figura 11 - Distribuição dos níveis de maturidade das organizações nas dimensões de Gestão de TIC



(Fonte: elaboração própria)

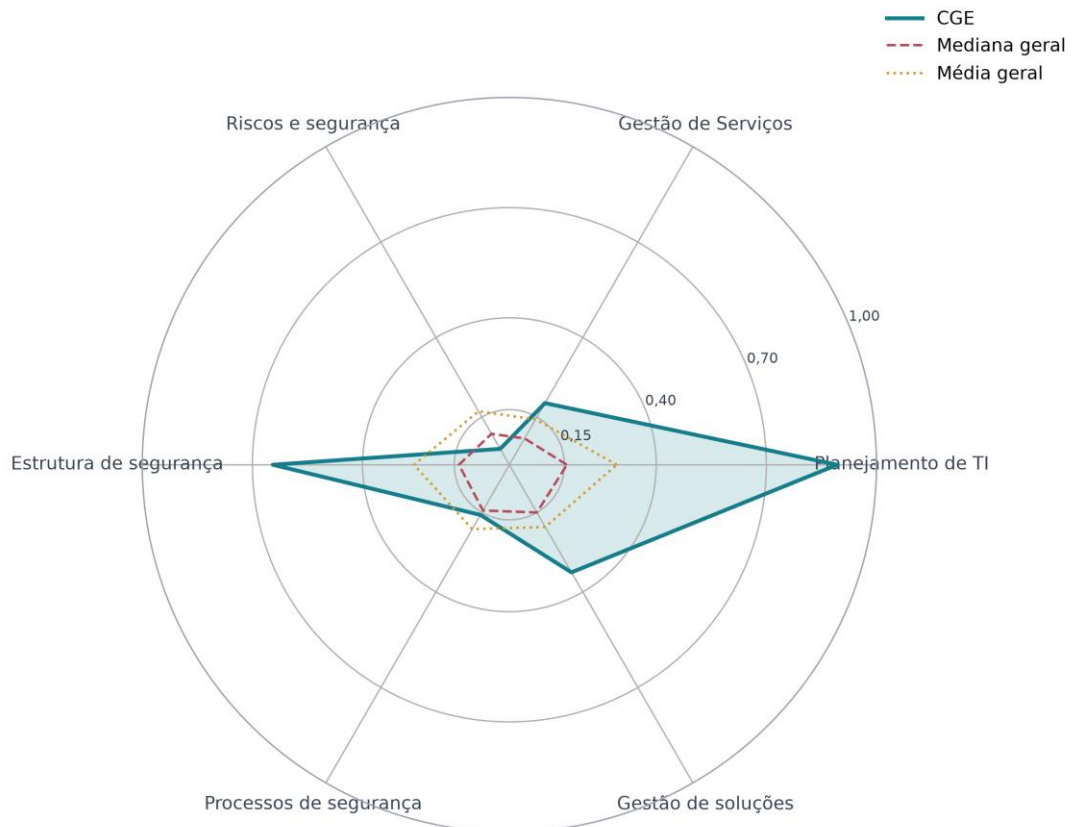
As menores médias foram observadas em **Gestão de serviços de TIC** (0,143) e **Riscos de TI e de segurança da informação** (0,168). A primeira registrou valor inferior a 0,40 em 102 organizações (89,5%) e apareceu entre as dimensões de menor resultado de 37 organizações (32,5%), considerados os empates. Para a segunda, esses quantitativos foram, respectivamente, 97 (85,1%) e 39 (34,2%). O quadro indica que a formalização do planejamento, quando existente, frequentemente não é acompanhada, na mesma intensidade, pelas demais capacidades operacionais e de segurança.

A dimensão Estrutura de Segurança da Informação apresentou média de 0,260 e mediana de 0,137. Essa diferença, associada à ampla dispersão observada na Figura 10, evidencia heterogeneidade: um grupo de organizações possui estruturas de segurança mais consolidadas, enquanto parcela expressiva permanece próxima dos níveis inferiores. A dimensão Processos de Segurança da Informação mostrou mediana superior à de Estrutura de Segurança da Informação, mas 83,3% das organizações ainda permaneceram abaixo de 0,40, o que recomenda examinar separadamente a existência da estrutura formal e a execução contínua dos processos de segurança.

2.5. Leitura integrada do resultado individual

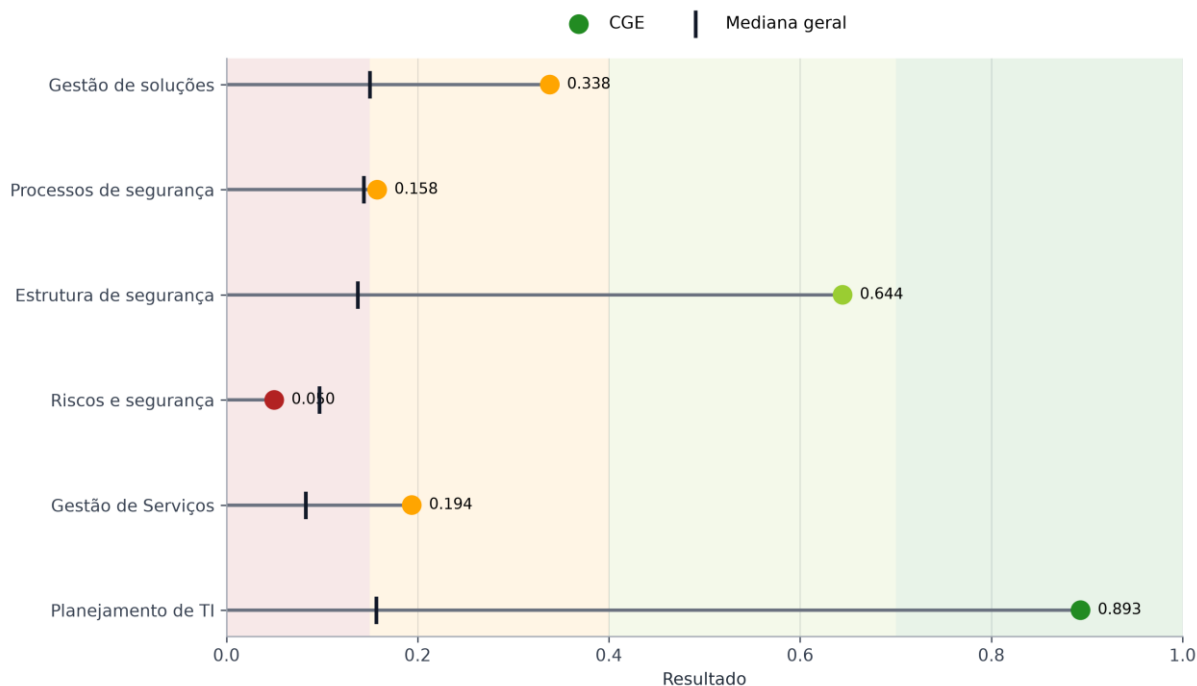
A Figura 12 apresenta o perfil da organização **CGE** nas seis dimensões de gestão e o compara com as medianas observadas nas 114 organizações. A comparação linear da Figura 13 permite identificar com maior precisão a distância entre o resultado individual e a mediana geral em cada dimensão.

Figura 12 - Perfil da organização nas dimensões de Gestão de TIC em comparação com os demais



(Fonte: elaboração própria)

Figura 13 - Comparação do resultado individual e da mediana nas dimensões de Gestão de TIC

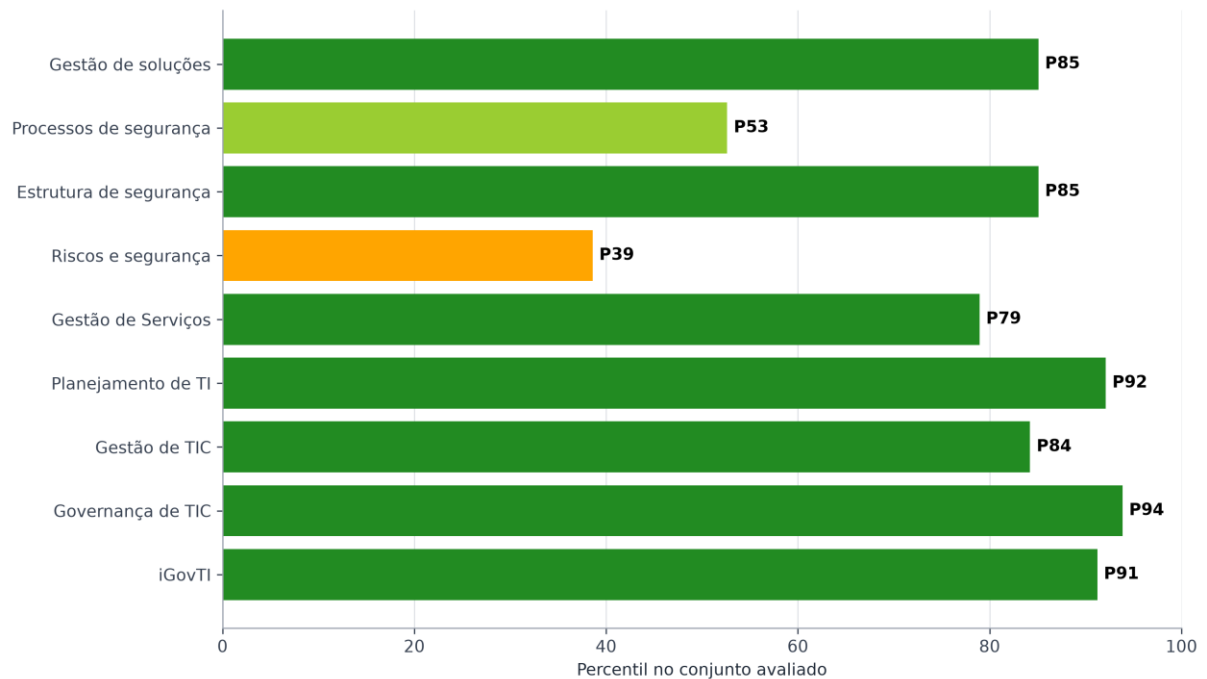


(Fonte: elaboração própria)

A Figura 14 compara a posição da organização **CGE** com as demais organizações avaliadas em cada indicador. A letra “P” indica a posição relativa (percentil) no conjunto: **P50** representa posição próxima ao centro da distribuição; **P90** indica que a organização obteve resultado igual ou superior ao de aproximadamente 90% das organizações avaliadas; e **P20** indica que apenas cerca de 20% das organizações tiveram resultado igual ou inferior. Assim, quanto maior o valor de “P”, melhor é a posição relativa da organização naquele indicador.

Essa comparação deve ser interpretada com cautela. A posição relativa não substitui o valor do índice, o nível de maturidade nem a análise de conformidade realizada nos achados de auditoria. Ela serve apenas para indicar se o resultado da organização ficou relativamente abaixo, próximo ou acima do conjunto avaliado.

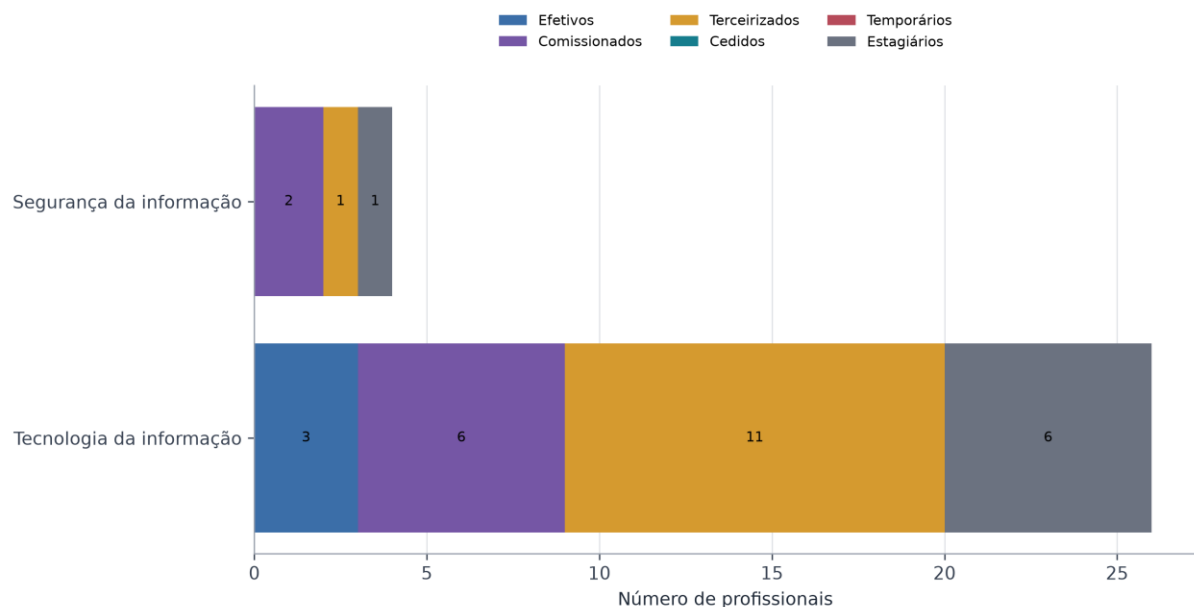
Figura 14 - Comparação da posição relativa da organização CGE nos indicadores avaliados



(Fonte: elaboração própria)

A composição declarada da força de trabalho de TIC e de segurança da informação é apresentada na Figura 15. Os quantitativos não compõem o índice e não medem, isoladamente, suficiência de pessoal; sua avaliação depende do porte, da complexidade, da terceirização, dos serviços mantidos e dos riscos da organização.

Figura 15 - Composição declarada da força de trabalho de TIC e segurança da informação



(Fonte: elaboração própria)

2.5.1. Evolução comparável entre 2023 e 2026

A análise longitudinal foi realizada exclusivamente para organizações com correspondência institucional validada nas bases de 2023 e 2026. Para reduzir os efeitos das alterações promovidas no questionário e na estrutura de cálculo, foram utilizados, em ambos os anos, índices ajustados formados por práticas e agregados comparáveis. Esses valores têm finalidade analítica e não substituem os resultados oficiais divulgados em cada ciclo.

No caso da organização **CGE**, o iGovTI ajustado comparável passou de 0,3577, em 2023, para 0,4337, em 2026, com variação absoluta de +0,0760.

O resultado indica avanço no conjunto harmonizado de práticas avaliadas, acompanhado da passagem do nível **Iniciando** para o nível **Intermediário** de maturidade.

Tabela 6 - Evolução dos componentes ajustados comparáveis da organização CGE

Indicador	2023	2026	Variação absoluta
iGovTI ajustado comparável	0,3577	0,4337	+0,0760
Governança de TIC	0,3251	0,4777	+0,1526
Gestão de TIC	0,3903	0,3897	-0,0006

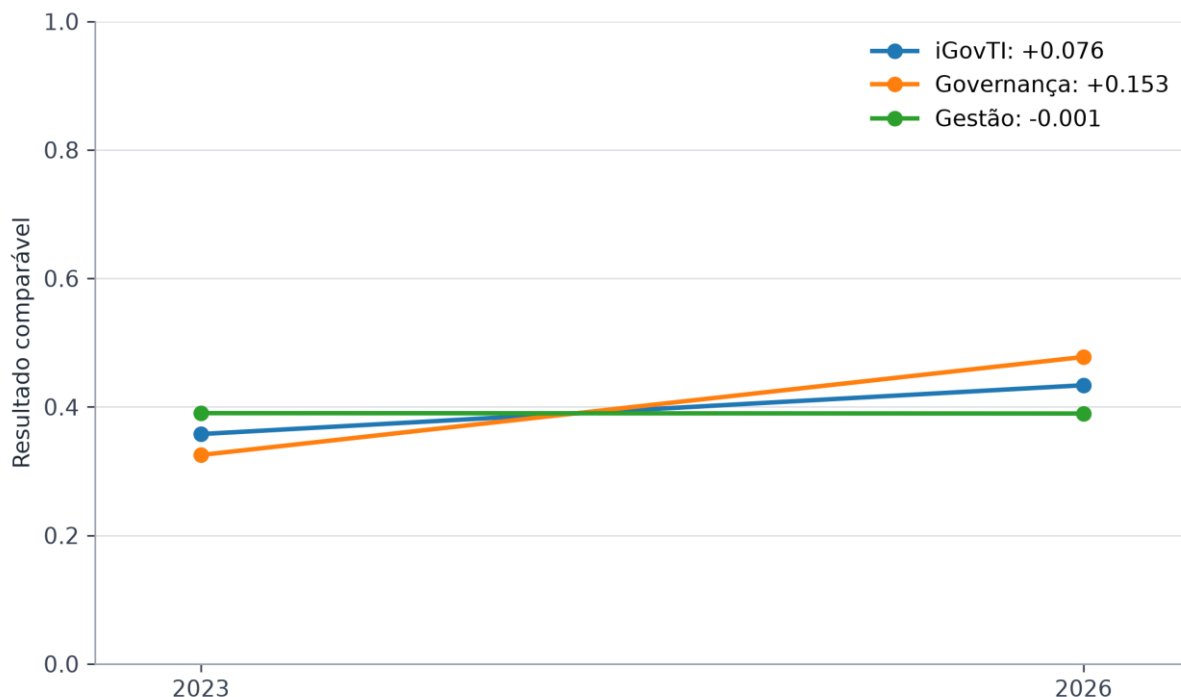
(Fonte: elaboração própria)

Os principais avanços foram observados em Estrutura de segurança da informação (+0.5488); Modelo de gestão de TIC (+0.3778); Planejamento de TIC (+0.2783).

As principais regressões foram observadas em Processos de contratação de TIC (-0.6246); Processo de software (-0.3792); Gestão de pessoas de TIC (-0.3412).

A Figura 16 apresenta a trajetória dos três indicadores. A variação deve ser interpretada como mudança nas respostas às práticas harmonizadas, e não como comprovação isolada de melhora ou piora da efetividade da TIC. A leitura deve considerar eventuais alterações institucionais, a qualidade das informações declaradas e os achados de auditoria apresentados neste relatório.

Figura 16 - Evolução comparável da organização CGE entre 2023 e 2026



(Fonte: elaboração própria)

A priorização de melhorias não deve buscar apenas a elevação numérica do índice. Recomenda-se concentrar esforços nas capacidades com menor resultado que, simultaneamente, estejam associadas a riscos relevantes, serviços críticos, obrigações normativas e necessidades institucionais da organização **CGE**.

3. Resultados da Auditoria

No âmbito desta fiscalização, foram definidas questões de auditoria para orientar a avaliação da governança e da gestão de TIC. Para fins deste relatório individual preliminar, os possíveis achados decorrem da verificação das Questões 1 a 6.

Tabela 7 - Questões de auditoria com avaliação individual preliminar

Questão	Tema	Síntese do objeto avaliado
Q1	Estrutura de TIC	Existência formal, atribuições e posicionamento organizacional da área, unidade, setor ou função responsável pela TIC.
Q2	Governança e comitê de TIC	Modelo de governança e gestão de TIC, objetivos, indicadores, metas e atuação do comitê ou instância equivalente.
Q3	Planejamento de TIC	Processo de planejamento, plano de TIC vigente, aprovação, alinhamento institucional, integração orçamentária e acompanhamento.
Q4	Capacidade institucional de TIC e segurança da informação	Força de trabalho, perfis, competências, funções, vínculos e capacidade interna para sustentar a TIC e a segurança da informação.
Q5	Gestão de serviços de TIC	Catálogo de serviços, níveis mínimos de serviço, inventário de ativos, gestão de configuração e tratamento de incidentes.
Q6	Contratações de TIC	Fluxo de contratação, papéis, modelos orientativos, aprovação técnica, alinhamento ao planejamento e equipe de planejamento.

(Fonte: elaboração própria)

Não foram identificados achados individuais preliminares relacionados às Questões 1 e 2 para esta organização. Por essa razão, os achados apresentados a seguir preservam a numeração vinculada às questões de auditoria que lhes deram origem.

Os achados de auditoria decorrem da avaliação preliminar das respostas da organização **CGE** ao questionário iGovTI 2026 e da correspondente análise de consistência documental realizada por esta Equipe de Auditoria. O trabalho consistiu no confronto sistemático entre as práticas de governança e gestão autodeclaradas pela organização e as evidências comprobatórias efetivamente encaminhadas, à luz da legislação aplicável e de padrões técnicos de referência internacional.

O presente relatório individual adota uma estrutura analítica de apresentação voltada a conferir clareza, rastreabilidade e utilidade diagnóstica às constatações. Desse modo, cada achado de auditoria está estruturado a partir dos seguintes elementos fundamentais:

- **Critérios:** as referências normativas, legais, regulamentares ou de boas práticas de gestão (como os objetivos do COBIT 2019 e normas da série ABNT NBR ISO/IEC) que estabelecem o padrão esperado de conformidade;

- **Evidências:** a relação das informações e dos documentos anexados pela organização que serviram de suporte factual para as constatações;
- **Situação Encontrada:** a descrição detalhada da realidade operacional e documental identificada no jurisdicionado, destacando-se as fragilidades e lacunas específicas em relação aos critérios adotados;
- **Conclusão da Equipe de Auditoria:** a análise técnica e o juízo profissional formulado a partir da correlação entre a situação factual e as regras de controle estabelecidas no mapa de verificação;
- **Propostas de Encaminhamento:** as recomendações preliminares propostas com o intuito de orientar a organização na correção de fragilidades e no aprimoramento de suas capacidades de governança e gestão de TIC.

Cumprе ressaltar o caráter preliminar das constatações ora apresentadas. A disponibilização deste relatório visa subsidiar a fase de comentários do gestor, permitindo à organização apresentar esclarecimentos adicionais, correções de fato ou novas informações que possam orientar a manifestação final desta Corte de Contas.

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

Critérios

- COBIT 2019, APO02.05 - Definir o plano e o roteiro estratégico: estabelecer plano e roteiro de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados;
- COBIT 2019, APO06.03 - Criar e manter orçamentos: elaborar e manter orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas;
- Acórdão 1.411/2014-TCU-Plenário, item 9.1.6 e subitens 9.1.6.1 a 9.1.6.4: necessidade de instituir formalmente plano diretor de TI, contemplando desdobramento de diretrizes estratégicas, vinculação das ações de TI a indicadores e metas de negócio, vinculação das ações de TI a indicadores e metas de serviços ao cidadão e vinculação das ações priorizadas ao orçamento de TI;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.3 e subitens II.3.1 a II.3.5: necessidade de estabelecer processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI, contemplando objetivos, indicadores e metas de TI alinhados aos objetivos de negócio, riscos que possam impactar objetivos e metas, projetos, aquisições e ações necessárias, alocação de recursos e ações de divulgação e monitoramento do PDTI após aprovação pela autoridade máxima.

Evidências

- **E1:** Resposta negativa ao detalhamento c) do item 2101 do Questionário, para verificar se as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações);
- **E2:** A organização declarou “Sim” no subitem c) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
 - Justificativa da avaliação: Não é possível verificar se o PCA considera os demais instrumentos de planejamento da organização, visto que o PCA não foi apresentado. O PEDTIC demonstra, nas páginas 4, 13 e 14, estar em consonância com o Plano Estratégico (PEI), o Plano Plurianual (PPA) e a Lei Orçamentária Anual (LOA), contudo, tal integração é restrita ao plano de tecnologia da informação. Inexiste evidência da articulação entre o plano de contratações e os instrumentos de planejamento institucional;

- **E3:** A organização declarou “Sim” no subitem d) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização;
 - Justificativa da avaliação: Não foi demonstrado que o planejamento de contratações sirva de fundamento para a proposta orçamentária da organização. Embora o PEDTIC apresente a tabela ‘Despesas Planejadas PEDTIC - 2025’ (p. 16), com previsão de gastos e alinhamento à LOA, a evidência indica que o orçamento é um insumo para o PEDTIC, e não que o planejamento de contratações preceda ou baseie a proposta orçamentária. Ausente a comprovação da relação direta entre o PCA e o fundamento da proposta da Lei Orçamentária Anual.

Situação encontrada

O planejamento de TIC é instrumento fundamental para traduzir diretrizes institucionais em iniciativas, prioridades, recursos, prazos, responsáveis e resultados esperados. Sob a perspectiva de governança pública, a administração deve executar processo formal de planejamento, contar com plano de TIC formalmente aprovado, assegurar participação das áreas finalísticas, alinhar o plano ao planejamento institucional, integrá-lo ao orçamento e às contratações e acompanhá-lo periodicamente.

Os critérios de boas práticas indicam que o planejamento de TIC deve estabelecer plano e roteiro estratégico, manter orçamento alinhado ao portfólio e às prioridades aprovadas, vincular ações de TIC a indicadores, metas e orçamento de TI, e contemplar processo estruturado de elaboração, manutenção e revisão periódica do PDTI¹.

Com base na análise das respostas aos itens 2101, 2102, 2802 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de planejamento. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo formal de planejamento:** a fragilidade no processo de elaboração não demonstra aderência aos critérios do COBIT 2019 (APO02.05), do Acórdão 1.411/2014-TCU-Plenário e do Acórdão TCE-RJ 44.490/2024-PLEN, o que pode favorecer atuação reativa e sem critérios objetivos de seleção e priorização de iniciativas.
- **Integração orçamentária e operacional:** a ausência de vínculo demonstrado com orçamento e contratações de TIC não demonstra aderência ao COBIT 2019 (APO06.03), ao Acórdão 1.411/2014-TCU-Plenário e ao Acórdão TCE-RJ

¹ Os critérios de planejamento de TIC convergem para a necessidade de plano formal, aprovado, vigente, alinhado à estratégia institucional, integrado ao orçamento e às contratações e acompanhado periodicamente.

44.490/2024-PLEN, favorecendo aquisições reativas, não priorizadas e desalinhadas das metas de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal de planejamento de TIC

O processo formal de planejamento de TIC deve definir etapas, responsáveis, participação das áreas demandantes e critérios mínimos de priorização. Esse processo é necessário para que o planejamento deixe de ser uma atividade eventual e passe a constituir rotina institucional de identificação, seleção, priorização e acompanhamento de demandas de tecnologia.

O COBIT 2019, no objetivo APO02.05, orienta a definição de plano e roteiro estratégico de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.3, também aponta a necessidade de processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI.

O processo deve ser demonstrado por norma, procedimento, guia ou instrumento equivalente que discipline a elaboração, revisão, aprovação e acompanhamento do planejamento de TIC.

Da análise das respostas ao item 2101 e da documentação apresentada, verificou-se que o processo formal de planejamento de TIC não se mostrou suficientemente estruturado quanto a etapas, responsáveis, participação das áreas demandantes e critérios de priorização, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2101, não houve declaração afirmativa quanto à prática avaliada: as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações) (E1).

A inexistência ou fragilidade desse processo expõe a organização a uma atuação reativa e à alocação de recursos em iniciativas de tecnologia sem critérios claros de priorização.

Vínculo com orçamento e contratações de TIC

O planejamento de TIC deve ser vinculado com a proposta orçamentária, o plano de contratações e as contratações executadas. Essa integração é necessária para que as iniciativas priorizadas tenham suporte financeiro, sejam convertidas em contratações coerentes e possam ser acompanhadas ao longo da execução.

O COBIT 2019, APO06.03, orienta a criação e manutenção de orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas. O Acórdão 1.411/2014-

TCU-Plenário também exige vinculação das ações priorizadas ao orçamento de TI, e o Acórdão TCE-RJ 44.490/2024-PLEN prevê projetos, aquisições, ações necessárias e alocação de recursos no PDTI.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o vínculo entre o plano de TIC, a proposta orçamentária, o plano de contratações ou as contratações de TIC executadas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E2);
- No subitem d) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização (E3).

A falta de integração demonstrada entre o planejamento de tecnologia, as previsões orçamentárias, o plano de contratações e as contratações executadas eleva o risco de aquisições isoladas, reativas ou insuficientemente priorizadas sob a perspectiva técnica.

Conclusão

As fragilidades identificadas no planejamento de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de processo e instrumento suficientes para direcionar iniciativas, priorizar recursos, alinhar projetos às necessidades institucionais e integrar orçamento e contratações à estratégia de tecnologia.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de planejamento de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC;
- **Comunicação com Recomendação** para que integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização.

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

Critérios

- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TIC;
- COBIT 2019, APO07.01 - Adquirir e manter pessoal adequado e apropriado: assegurar quantidade e perfil de profissionais compatíveis com as necessidades de TIC;
- COBIT 2019, APO07.02 - Identificar pessoal-chave de TI: identificar funções e pessoas críticas para reduzir dependência individual, perda de conhecimento e descontinuidade;
- COBIT 2019, APO07.03 - Manter habilidades e competências do pessoal: identificar, desenvolver e manter competências necessárias à execução das responsabilidades de TIC;
- COBIT 2019, APO07.05 - Planejar e monitorar o uso de recursos humanos de TI e de negócio: planejar, alocar e acompanhar capacidade de pessoal para iniciativas, operações e serviços de TIC;
- COBIT 2019, APO07.06 - Gerenciar pessoal contratado: controlar o uso de pessoal terceirizado ou externo, preservando responsabilização, supervisão e retenção de conhecimento;
- COBIT 2019, APO10.04 - Gerenciar risco de fornecedores: identificar e tratar riscos decorrentes de fornecedores, contratos e dependências externas relevantes para TIC;
- COBIT 2019, DSS01.02 - Gerenciar serviços de TI terceirizados: assegurar que serviços terceirizados sejam supervisionados, medidos e integrados aos controles da organização;
- ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2: definir responsabilidades e autoridades para segurança da informação e assegurar competências necessárias às funções atribuídas;
- ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3: definir papéis e responsabilidades de segurança da informação e promover conscientização, educação e treinamento em segurança.

Evidências

- **E1:** A organização declarou “Sim” no subitem c) do item 2703, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação;
 - Justificativa da avaliação: Não existe evidência documental que registre a definição de um quantitativo necessário de pessoal. A captura de tela exibida contém apenas a listagem de um diretório de arquivos sem conteúdo técnico legível, e os demais documentos não tratam de metas ou quantitativos de pessoal definido;
- **E2:** A organização declarou “Sim” no subitem b) do item 2708, mas a evidência encaminhada foi considerada insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação;
 - Justificativa da avaliação: A avaliação realizada aponta que os documentos apresentados são insuficientes para demonstrar a atribuição formal de cargos ou funções à área de tecnologia da informação. Os formulários de avaliação de desempenho referem-se à situação funcional individual e não constituem ato formal de designação ou estruturação da área. Faz-se necessária a apresentação de norma ou ato administrativo que formalize a atribuição dessas funções à unidade;
- **E3:** A organização declarou “Sim” no subitem b) do item 2704, mas a evidência encaminhada foi considerada insuficiente para comprovar que os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado;
 - Justificativa da avaliação: A documentação apresentada restringe-se a atos de designação, sem demonstrar a existência de perfis profissionais documentados ou a aplicação de critérios de seleção que validem a compatibilidade entre o perfil dos designados e as atribuições das funções ocupadas;
- **E4:** Resposta negativa ao detalhamento b) do item 2705 do Questionário, para verificar se as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas;
- **E5:** Resposta negativa ao detalhamento c) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de tecnologia da

informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;

- **E6:** Resposta negativa ao detalhamento d) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E7:** Predomínio de profissionais terceirizados de TI em relação ao quantitativo de profissionais internos, conforme informado em resposta ao item 0105.

Situação encontrada

A capacidade institucional de TIC e segurança da informação pressupõe dispor de recursos humanos, competências, perfis profissionais, funções e vínculos contratuais adequados para planejar, coordenar, gerir, proteger, contratar, fiscalizar e sustentar o ambiente tecnológico. Sob a perspectiva de controle e governança, a estruturação formal de uma unidade de tecnologia deve ser acompanhada de capacidade técnica compatível para exercer a supervisão de suas atribuições estratégicas.

Os critérios de boas práticas indicam que a organização deve formalizar a designação de papéis e responsabilidades, assegurar o dimensionamento apropriado do quadro de pessoal, mapear funções críticas, capacitar periodicamente a equipe e supervisionar de forma estrita a atuação de prestadores de serviços externos².

Com base na análise das respostas aos itens 0101, 0105, 2701, 2702, 2703, 2704, 2705, 2706, 2708, 2801 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada capacidade institucional suficiente para sustentar a gestão de TIC e segurança da informação. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Dimensionamento de pessoal:** a ausência de definição de parâmetros de pessoal não demonstra aderência aos critérios de planejamento de recursos humanos (COBIT 2019, APO07.01), elevando o risco de subdimensionamento ou má alocação da equipe técnica.
- **Cargos e carreiras específicas:** a ausência de cargos, funções ou perfis técnicos estruturados não demonstra aderência às boas práticas de atração e retenção de pessoal (COBIT 2019, APO07.01), podendo reduzir a responsabilização e a continuidade da gestão tecnológica.
- **Perfis profissionais:** a ausência ou inobservância de perfis profissionais mínimos para a escolha de gestores e técnicos não demonstra aderência às diretrizes de

² Os critérios de capacidade institucional de TIC e segurança da informação concentram-se em pessoal adequado, competências, papéis, responsabilidades, retenção de conhecimento e supervisão de terceiros.

manutenção de competências (COBIT 2019, APO07.01/APO07.03 e ISO/IEC 27002:2022, 5.2/6.3), reduzindo a segurança de que os responsáveis possuam qualificação compatível com as funções exercidas.

- **Lacunas de competência:** a ausência de identificação ou tratamento de lacunas de treinamento não demonstra aderência às recomendações de capacitação técnica (COBIT 2019, APO07.03 e ISO/IEC 27002:2022, 6.3), podendo fragilizar a operação de segurança e o gerenciamento de ativos de TIC.
- **Dependência externa:** a dependência externa relevante sem capacidade interna suficiente para coordenar e fiscalizar a TIC não demonstra aderência às boas práticas de gestão de pessoal contratado e terceirizações (COBIT 2019, APO07.06, APO10.04 e DSS01.02), elevando riscos à governabilidade técnica e à continuidade das atividades do órgão.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Quantitativo necessário de pessoal de TIC e segurança da informação

A definição do quantitativo necessário de pessoal permite avaliar se a força de trabalho disponível é compatível com as demandas, riscos e responsabilidades da organização.

O COBIT 2019, APO07.01 e APO07.05, exige que a organização assegure quantidade e perfil de profissionais compatíveis com as necessidades de TIC e planeje a alocação de recursos humanos para iniciativas, operações e serviços.

Da análise das respostas ao item 2703 e da documentação apresentada, verificou-se que a definição do quantitativo necessário de pessoal de TIC e segurança da informação com base em critério ou procedimento técnico não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2703, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação (E1).

A ausência de dimensionamento técnico do quadro de pessoal reduz a disponibilidade de bases objetivas para subsidiar decisões sobre contratações, provimentos, planos de capacitação ou eventual compartilhamento de estruturas com outras organizações.

Cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação

Cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação ajudam a estruturar responsabilidades, atrair profissionais, definir requisitos mínimos e reduzir improvisação na alocação de pessoas.

O COBIT 2019, APO01.05, APO07.01 e APO07.02, orienta a definição de papéis e responsabilidades, a manutenção de pessoal adequado e a identificação de funções críticas de TI.

Da análise das respostas ao item 2708 e da documentação apresentada, verificou-se que a existência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2708, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação (E2).

A ausência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação pode reduzir a capacidade de atração, responsabilização e retenção de profissionais com perfil compatível com as necessidades da área.

Perfis profissionais de TIC e segurança da informação

A definição de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação é necessária para que as pessoas designadas possuam competências compatíveis com suas responsabilidades.

O COBIT 2019, APO01.05 e APO07.03, orienta a definição de papéis, responsabilidades e competências necessárias. A ABNT NBR ISO/IEC 27001:2022 também exige competências adequadas às funções atribuídas em segurança da informação.

Da análise das respostas aos itens 2701, 2702 e 2704 e da documentação apresentada, verificou-se que a definição ou utilização de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2704, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado (E3).

A ausência de perfis profissionais mínimos ou de sua utilização como referência para designação de gestores e técnicos eleva o risco de alocação de colaboradores sem

qualificação compatível com atividades críticas de tecnologia da informação e segurança da informação.

Identificação e tratamento de lacunas de competências

A organização deve identificar periodicamente lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e definir medidas de tratamento, como capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

O COBIT 2019, APO07.03, orienta a manutenção de habilidades e competências necessárias à execução das responsabilidades de TIC. A ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3, reforça a definição de responsabilidades e a promoção de conscientização, educação e treinamento em segurança.

Da análise das respostas aos itens 2705 e 2706 e da documentação apresentada, verificou-se que a identificação ou o tratamento de lacunas de competências dos gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas (E4);
- No subitem c) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E5);
- No subitem d) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E6).

A ausência de diagnóstico regular sobre competências internas e de medidas para tratamento de lacunas dificulta o acompanhamento da evolução tecnológica e pode reduzir a capacidade da equipe técnica de administrar sistemas, infraestrutura e controles de segurança da informação de forma compatível com os riscos existentes.

Dependência externa e capacidade interna de coordenação e fiscalização

A utilização de terceiros ou de estrutura externa para execução de atividades de TIC não elimina a responsabilidade da organização pela coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento.

O COBIT 2019, APO07.06, APO10.04 e DSS01.02, orienta o controle de pessoal contratado, a gestão de riscos de fornecedores e a supervisão de serviços terceirizados de TI, preservando responsabilização, medição, integração aos controles e retenção de conhecimento.

Da análise das respostas aos itens 0101 e 0105 e da documentação apresentada, verificou-se que a existência de capacidade interna para coordenar, planejar, fiscalizar e reter conhecimento quando a operação de TIC depende de terceiros ou de estrutura externa não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- O quantitativo informado indicou predominância de profissionais terceirizados em relação aos profissionais internos de TIC (E7).

O estabelecimento de modelo operacional baseado predominantemente em recursos externos, sem capacidade interna suficiente de coordenação e supervisão, pode reduzir a governabilidade técnica, a retenção de conhecimento e a continuidade das operações de TIC.

Conclusão

As fragilidades identificadas na capacidade institucional de TIC e segurança da informação reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de pessoal, competências, papéis, perfis profissionais e mecanismos de supervisão suficientes para sustentar a gestão, a proteção, as contratações, a fiscalização e a continuidade dos serviços tecnológicos.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de capacidade institucional de TIC e segurança da informação efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes;
- **Comunicação com Recomendação** para que avalie a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização;

- **Comunicação com Recomendação** para que defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis;
- **Comunicação com Recomendação** para que realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento;
- **Comunicação com Recomendação** para que avalie o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa.

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

Critérios

- ITIL 4, prática de gerenciamento do catálogo de serviços: manter fonte única de informações consistentes sobre serviços e ofertas de serviço, disponível para usuários e equipes de suporte;
- COBIT 2019, APO09.02 - Catalogar serviços facilitados por TI: definir, manter e comunicar catálogo de serviços, incluindo serviços prestados, características, requisitos e níveis de serviço esperados;
- ITIL 4, prática de gerenciamento de nível de serviço: definir, acordar, monitorar, avaliar e reportar metas e níveis de serviço alinhados às necessidades das áreas usuárias;
- ITIL 4, prática de gerenciamento de ativos de TI: planejar e gerenciar o ciclo de vida dos ativos de TI, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão;
- ITIL 4, prática de gerenciamento de configuração de serviço: assegurar informações precisas e confiáveis sobre itens de configuração e seus relacionamentos com serviços, sistemas e infraestrutura;
- COBIT 2019, BAI10.01 - Estabelecer e manter um modelo de configuração: definir escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração;
- ITIL 4, prática de gerenciamento de incidentes: minimizar o impacto negativo dos incidentes por meio da restauração tempestiva da operação normal dos serviços e do registro rastreável do tratamento realizado;
- COBIT 2019, DSS02.02, DSS02.04 e DSS02.07 - Requisições de serviço e incidentes gerenciados: registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Evidências

- **E1:** Resposta negativa ao detalhamento a) do item 2201 do Questionário, para verificar se o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes);

- **E2:** Resposta negativa ao detalhamento b) do item 2201 do Questionário, para verificar se o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização;
- **E3:** Resposta negativa ao detalhamento c) do item 2201 do Questionário, para verificar se o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte;
- **E4:** Resposta negativa ao detalhamento d) do item 2201 do Questionário, para verificar se são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes;
- **E5:** Resposta negativa ao detalhamento e) do item 2201 do Questionário, para verificar se a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS;
- **E6:** A organização declarou “Sim” no subitem a) do item 2203, mas a evidência encaminhada foi considerada insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles;
 - Justificativa da avaliação: Não foi demonstrada a existência de uma base de dados de configuração (CMDB) ou inventário equivalente que consolide as configurações e relacionamentos dos ativos de TI. Os relatórios anexados referem-se exclusivamente a análises de vulnerabilidades de segurança e não contêm informações sobre o mapeamento de configurações ou ativos tecnológicos. A ausência de um repositório centralizado impede a verificação da conformidade com o requisito de manutenção de base de dados de configuração;
- **E7:** A organização declarou “Sim” no subitem a) do item 2504, mas a evidência encaminhada foi considerada insuficiente para comprovar que gerencia (inventaria e controla) os dispositivos conectados em sua rede;
 - Justificativa da avaliação: Não foram fornecidas evidências documentais de um processo formal, ferramenta de inventário ou controle centralizado de dispositivos conectados à rede. Os relatórios de teste de segurança mencionam ativos apenas no contexto de descoberta pontual para análise de vulnerabilidades;
- **E8:** A organização declarou “Sim” no subitem b) do item 2504, mas a evidência encaminhada foi considerada insuficiente para comprovar que gerencia (inventaria e controla) os softwares instalados nos dispositivos conectados em sua rede;

- Justificativa da avaliação: Não foram apresentadas evidências de um processo estruturado de inventário e controle de softwares instalados nos dispositivos. As menções a softwares em relatórios de pentest referem-se a identificação por scanners durante testes de intrusão, não a uma prática de gestão de inventário organizacional;
- **E9:** Resposta negativa ao detalhamento c) do item 2203 do Questionário, para verificar se o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
- **E10:** A organização declarou “Sim” no subitem a) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu regras para a priorização e o escalamento de incidentes;
 - Justificativa da avaliação: A evidência comprova a existência de critérios de priorização baseados em urgência e impacto, com geração automática de matriz de prioridade. Entretanto, não foram apresentados documentos ou registros que estabeleçam formalmente os procedimentos de escalamento de incidentes, como níveis hierárquicos, prazos ou gatilhos para movimentação entre grupos técnicos;
- **E11:** A organização declarou “Sim” no subitem e) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa;
 - Justificativa da avaliação: Embora o tratamento operacional de incidentes de segurança esteja evidenciado por meio de registros de remediação, não há documentação comprovando os procedimentos para notificação formal de incidentes de segurança, nem as diretrizes de comunicação interna e externa exigidas. A ausência desses elementos impede a conformidade integral com o critério estabelecido.

Situação encontrada

A gestão de serviços de TIC organiza a forma como as soluções e o suporte tecnológico são entregues aos usuários e às áreas demandantes do órgão. Catálogo de serviços, Acordos de Nível de Serviço (ANS), inventário de ativos, gestão de configuração e gestão de incidentes constituem práticas básicas e integradas necessárias para assegurar a

transparência operacional, continuidade do negócio, governabilidade financeira, controle de ativos e qualidade de suporte técnico.

Os critérios de boas práticas baseados na ITIL 4 e no COBIT 2019 indicam que a organização deve manter fonte unificada e consistente de informações sobre seu catálogo, estabelecer metas mensuráveis de atendimento, administrar ativamente o ciclo de vida dos ativos tecnológicos, rastrear os relacionamentos lógicos de configuração e registrar de forma sistemática e auditável todas as ocorrências operacionais e incidentes de segurança³.

Com base na análise das respostas aos itens 2201, 2203, 2204 e 2504 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada adoção suficiente dessas práticas mínimas. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Catálogo de serviços de TIC:** a fragilidade ou ausência do catálogo não demonstra aderência à ITIL 4 e ao COBIT 2019 (APO09.02), podendo resultar em prestação reativa, sem transparência ou definição clara das entregas técnicas disponíveis.
- **Níveis mínimos de serviço:** a ausência de parâmetros ou acompanhamento não demonstra aderência aos critérios de catálogo e gerenciamento de nível de serviço (ITIL 4 e COBIT 2019, APO09.02), dificultando a avaliação objetiva da qualidade e tempestividade dos serviços prestados.
- **Inventário de ativos de TIC:** a fragilidade ou inexistência de inventário não demonstra aderência à prática de gerenciamento de ativos de TI (ITIL 4), reduzindo o controle sobre recursos tecnológicos, licenciamentos de software, custos e riscos associados.
- **Gestão de configuração:** a ausência de mapeamento lógico não demonstra aderência à ITIL 4 e ao COBIT 2019 (BAI10.01), podendo prejudicar a confiabilidade das dependências operacionais entre infraestrutura, sistemas e serviços críticos.
- **Gestão de incidentes de TIC:** a inexecução ou informalidade no processo de atendimento não demonstra aderência à ITIL 4 e ao COBIT 2019 (DSS02.02, DSS02.04 e DSS02.07), dificultando o tratamento padronizado, tempestivo e rastreável de falhas tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Catálogo de serviços de TIC

O catálogo de serviços de TIC deve constituir fonte única de informações consistentes sobre os serviços prestados, acessível aos usuários e às áreas demandantes.

³ As práticas de gestão de serviços de TIC adotadas como critério baseiam-se em ITIL 4 e COBIT 2019 e abrangem catálogo, níveis de serviço, ativos, configuração e incidentes.

Deve conter informações mínimas sobre os serviços efetivamente prestados, suas características, requisitos, canais de atendimento e níveis esperados de serviço.

A ITIL 4, na prática de gerenciamento do catálogo de serviços, orienta a manutenção de informações consistentes e disponíveis sobre serviços e ofertas de serviço. O COBIT 2019, APO09.02, exige a definição, manutenção e comunicação do catálogo de serviços facilitados por TI.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a existência de catálogo de serviços de TIC atualizado, acessível aos usuários e com informações mínimas sobre os serviços prestados não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes) (E1);
- No subitem b) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização (E2);
- No subitem c) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte (E3).

A inexistência, desatualização ou falta de divulgação do catálogo de serviços dificulta que os usuários conheçam o portfólio de entregas e os canais corretos de atendimento, elevando o risco de prestação de suporte de forma reativa, informal ou pouco transparente.

Níveis de serviço e metas de atendimento

A definição de Acordos de Níveis de Serviço, metas mínimas ou parâmetros equivalentes permite pactuar expectativas, medir desempenho e avaliar a qualidade dos principais serviços de TIC.

A ITIL 4, na prática de gerenciamento de nível de serviço, orienta a definição, monitoramento, avaliação e reporte de metas e níveis de serviço alinhados às necessidades das áreas usuárias. O COBIT 2019, APO09.02, também relaciona o catálogo à comunicação de requisitos e níveis de serviço esperados.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a definição ou o monitoramento de níveis mínimos de serviço, metas ou parâmetros

equivalentes para os serviços de TIC relevantes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2201, não houve declaração afirmativa quanto à prática avaliada: são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes (E4);
- No subitem e) do item 2201, não houve declaração afirmativa quanto à prática avaliada: a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS (E5).

A ausência de níveis mínimos de serviço, metas estruturadas ou parâmetros equivalentes reduz a disponibilidade de bases objetivas para monitorar e avaliar a qualidade, o tempo de resposta e a eficiência dos serviços prestados.

Inventário de ativos de TIC

O inventário de ativos de TIC deve permitir conhecer e controlar equipamentos, servidores, sistemas, *softwares*, licenças, serviços em nuvem, responsáveis e componentes de infraestrutura.

A ITIL 4, na prática de gerenciamento de ativos de TI, orienta o gerenciamento do ciclo de vida dos ativos, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão.

Da análise das respostas aos itens 2203 e 2504 e da documentação apresentada, verificou-se que a existência de inventário de ativos de TIC atualizado e abrangente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E6);
- No subitem a) do item 2504, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que gerencia (inventaria e controla) os dispositivos conectados em sua rede (E7);
- No subitem b) do item 2504, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que gerencia (inventaria e controla) os softwares instalados nos dispositivos conectados em sua rede (E8).

A ausência de inventário atualizado e abrangente de ativos de TIC reduz a segurança quanto ao controle sobre equipamentos, sistemas, softwares, licenças, serviços

em nuvem e componentes de infraestrutura, elevando riscos relacionados a custos, conformidade, segurança da informação e planejamento de capacidade.

Gestão de configuração

A gestão de configuração deve manter informações precisas e confiáveis sobre itens de configuração relevantes, seus atributos, responsáveis e relacionamentos com ativos, sistemas, infraestrutura e serviços.

A ITIL 4, na prática de gerenciamento de configuração de serviço, orienta assegurar informações confiáveis sobre itens de configuração e seus relacionamentos. O COBIT 2019, BAI10.01, exige a definição de escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração.

Da análise das respostas ao item 2203 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de configuração com registro de itens relevantes, atributos, responsáveis e relacionamentos entre ativos, sistemas, infraestrutura e serviços não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E6);
- No subitem c) do item 2203, não houve declaração afirmativa quanto à prática avaliada: o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E9).

A ausência de registros suficientes de configuração dificulta o mapeamento lógico das dependências entre servidores, bancos de dados, aplicações e serviços finalísticos, podendo reduzir a capacidade de análise de riscos em mudanças operacionais e de tratamento de falhas sistêmicas.

Gestão de incidentes de TIC

A gestão de incidentes de TIC deve definir papéis, responsabilidades, critérios de priorização, escalamento, tratamento, registro sistemático, histórico das ocorrências e análise posterior de incidentes relevantes ou recorrentes.

A ITIL 4, na prática de gerenciamento de incidentes, orienta minimizar impactos negativos por meio da restauração tempestiva da operação normal e do registro rastreável do tratamento realizado. O COBIT 2019, DSS02.02, DSS02.04 e DSS02.07, exige registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Da análise das respostas ao item 2204 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de incidentes de TIC com papéis, critérios de priorização, escalamento, tratamento, registro sistemático e análise posterior de ocorrências relevantes ou recorrentes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu regras para a priorização e o escalamento de incidentes (E10);
- No subitem e) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa (E11).

O tratamento assistemático ou sem registro centralizado das falhas tecnológicas dificulta o acompanhamento do histórico de incidentes, a identificação de causas raiz e a redução do período de indisponibilidade dos sistemas corporativos.

Conclusão

As fragilidades identificadas na gestão de serviços de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de práticas suficientes para assegurar eficiência, continuidade, rastreabilidade, qualidade dos serviços prestados e controle sobre ativos, configurações e incidentes.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação das práticas de gestão de serviços de TIC efetivamente apontadas neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes;
- **Comunicação com Recomendação** para que defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados;

- **Comunicação com Recomendação** para que estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes.

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

CrITÉRIOS

- Art. 11, parágrafo único, da Lei 14.133/2021: responsabilidade da alta administração pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos;
- Art. 18, caput e §1º, incisos I, IV, V, VIII, IX, X e XIII, da Lei 14.133/2021: fase preparatória caracterizada pelo planejamento, compatibilização com o plano de contratações anual e elementos mínimos do estudo técnico preliminar;
- Art. 19, inciso IV, da Lei 14.133/2021: instituição de modelos de minutas de editais, termos de referência, contratos padronizados e demais documentos;
- COBIT 2019, BAI02.04 - Obter aprovação dos requisitos da solução: obter aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir e comunicar papéis e responsabilidades relacionados à informação e à tecnologia;
- COBIT 2019, APO01.09 - Definir e comunicar políticas e procedimentos: manter políticas, procedimentos e orientações para direcionar processos de gestão de TIC;
- Instrução Normativa SGD/ME nº 94, de 23 de dezembro de 2022, art. 1º, § 1º: como referência de boa prática, a aplicação de ritos formais de contratação de TIC pode ser facultada para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando a possibilidade de fluxos simplificados para aquisições de baixa complexidade ou valor.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A evidência fornecida não demonstra a estrutura do processo de trabalho de planejamento, omitindo a descrição das etapas, responsabilidades e a definição dos fluxos. A suficiência é nula para o propósito de demonstrar um processo de trabalho estruturado, pois exhibe apenas registros de documentos individuais em uma contratação única;

- **E2:** A organização declarou “Sim” no subitem c) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A evidência não apresenta a definição do processo de trabalho para a seleção de fornecedores, limitando-se a listar documentos inseridos no SEI. Não há descrição de fluxo de trabalho ou das responsabilidades dos atores na referida fase, resultando em insuficiência documental;
- **E3:** A organização declarou “Sim” no subitem d) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes;
 - Justificativa da avaliação: Não há comprovação de modelos padronizados, minutas ou checklists para a seleção de fornecedores. A evidência contém documentos preenchidos para uma contratação específica, o que não equivale à disponibilização institucional de modelos para uso amplo;
- **E4:** A organização declarou “Sim” no subitem e) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A evidência não demonstra a definição de processos para a gestão e fiscalização contratual. Não foram identificadas descrições das etapas, responsabilidades ou fluxos de trabalho correspondentes, tornando a evidência insuficiente;
- **E5:** A organização declarou “Sim” no subitem g) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas;
 - Justificativa da avaliação: Como não houve a apresentação da definição dos processos e artefatos padronizados, não é possível avaliar a conformidade normativa dos mesmos. A evidência é insuficiente para atestar a aderência às normas legais vigentes;
- **E6:** A organização declarou “Sim” no subitem a) do item 2804, mas a evidência encaminhada foi considerada insuficiente para comprovar que as contratações de

soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI;

- Justificativa da avaliação: A evidência apresentada é insuficiente para comprovar a afirmação de que toda contratação de TI é obrigatoriamente submetida à análise prévia e aprovação técnica da área de gestão de TI. O Estudo Técnico Preliminar demonstra a participação de diretorias técnicas do PRODERJ apenas na estruturação de um processo de contratação específico para adequação à LGPD. O documento não apresenta norma administrativa, portaria ou regulamento de caráter geral que estabeleça essa prática como regra mandatória para o conjunto das contratações de soluções de tecnologia da informação da organização. Faz-se necessária a apresentação de instrumento formal que institucionalize a obrigatoriedade da submissão técnica para o fluxo de contratações de TI;
- **E7:** A organização declarou “Sim” no subitem c) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
 - Justificativa da avaliação: Não é possível verificar se o PCA considera os demais instrumentos de planejamento da organização, visto que o PCA não foi apresentado. O PEDTIC demonstra, nas páginas 4, 13 e 14, estar em consonância com o Plano Estratégico (PEI), o Plano Plurianual (PPA) e a Lei Orçamentária Anual (LOA), contudo, tal integração é restrita ao plano de tecnologia da informação. Inexiste evidência da articulação entre o plano de contratações e os instrumentos de planejamento institucional;
- **E8:** A organização declarou “Sim” no subitem d) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização;
 - Justificativa da avaliação: Não foi demonstrado que o planejamento de contratações sirva de fundamento para a proposta orçamentária da organização. Embora o PEDTIC apresente a tabela ‘Despesas Planejadas PEDTIC - 2025’ (p. 16), com previsão de gastos e alinhamento à LOA, a evidência indica que o orçamento é um insumo para o PEDTIC, e não que o planejamento de contratações preceda ou baseie a proposta orçamentária. Ausente a comprovação da relação direta entre o PCA e o fundamento da proposta da Lei Orçamentária Anual.

Situação encontrada

As contratações de TIC devem observar governança técnica, planejamento prévio proporcional à complexidade do objeto, participação da área de tecnologia quando cabível e critérios objetivos para recebimento e mensuração de resultados. A complexidade dos ativos de tecnologia, as exigências de conformidade legal, incluindo LGPD quando aplicável, e a dependência das atividades finalísticas em relação aos serviços de TIC demandam controles compatíveis com a relevância, o risco e o valor da contratação.

Os critérios previstos na Lei 14.133/2021, na Lei 13.709/2018 (LGPD) e nos objetivos do COBIT 2019 disciplinam que a alta administração responde pela governança das contratações, que a fase preparatória deve ser instruída com planejamento compatível com o objeto e que os Termos de Referência (TR), projetos básicos, contratos ou instrumentos equivalentes devem conter requisitos, modelos de execução, critérios de medição e parâmetros de acompanhamento proporcionais à natureza da contratação⁴.

Com base na análise das respostas aos itens 2801, 2804, 2102 e 2802 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento suficiente das contratações de TIC da organização a essas diretrizes. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo de contratação de TIC:** a fragilidade ou ausência de fluxo padronizado contraria a governança de contratações (Lei 14.133/2021, art. 11/art. 19, IV) e o COBIT 2019 (APO01.09), acarretando indefinição de papéis, ritos processuais e prazos internos.
- **Aprovação técnica de TIC:** a falta de avaliação prévia pela área técnica, quando necessária, contraria a governança institucional (COBIT 2019, BAI02.04 e APO01.05), favorecendo aquisições de soluções desalinhadas do ambiente tecnológico existente.
- **Alinhamento ao planejamento:** a ausência de alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não demonstra aderência à Lei 14.133/2021 (arts. 11 e 18), podendo resultar em aquisições reativas ou sem lastro orçamentário adequado.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

⁴ Os critérios de contratações de TIC combinam requisitos legais da Lei 14.133/2021, requisitos de segurança e proteção de dados da LGPD e boas práticas do COBIT 2019 sobre requisitos, papéis, procedimentos, contratos e desempenho de fornecedores.

Processo formal e padronizado para contratações de TIC

O processo de contratação de TIC deve estabelecer fluxo, etapas, papéis, responsabilidades, modelos mínimos de artefatos, manuais, checklists ou orientações internas. Esses elementos reduzem improvisação, aumentam padronização e permitem controle sobre a qualidade da instrução processual.

O art. 11, parágrafo único, da Lei 14.133/2021 atribui à alta administração responsabilidade pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos. O art. 19, inciso IV, prevê a instituição de modelos de documentos padronizados, e o COBIT 2019, APO01.09, orienta a definição e comunicação de políticas e procedimentos.

Da análise das respostas ao item 2801 e da documentação apresentada, verificou-se que a existência de processo formal e padronizado para contratações de TIC, com fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos proporcionais ao porte e aos riscos das contratações, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E1);
- No subitem c) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E2);
- No subitem d) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes (E3);
- No subitem e) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E4);
- No subitem g) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas (E5).

A ausência de fluxo processual regulamentado e de modelos padronizados reduz a segurança quanto à conformidade das contratações de TIC e eleva o risco de atrasos processuais, indefinição de papéis e inconsistências na elaboração dos documentos da fase preparatória.

Análise prévia e aprovação técnica da área de TIC

As contratações de TIC devem ser submetidas à análise prévia e aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas da organização. Essa análise é necessária para verificar compatibilidade técnica, segurança, integração com o ambiente existente, riscos e aderência a padrões institucionais.

O COBIT 2019, BAI02.04, orienta a obtenção de aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução. O COBIT 2019, APO01.05, reforça a definição de papéis e responsabilidades relacionados à informação e à tecnologia. De forma complementar, o art. 1º, § 1º, da Instrução Normativa SGD/ME nº 94/2022, adotado como referência de boa prática, aponta a possibilidade de facultar a aplicação de ritos formais para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando que os controles e pareceres podem ser proporcionais à relevância estratégica, complexidade e valor da aquisição.

Da análise das respostas ao item 2804 e da documentação apresentada, verificou-se que a submissão das contratações de TIC à análise prévia ou aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2804, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI (E6).

A ausência de análise prévia ou aprovação técnica da área de TIC reduz a segurança de que as soluções contratadas sejam compatíveis com o ambiente tecnológico existente, com os requisitos institucionais e com os controles mínimos de segurança da informação, observada a proporcionalidade em relação à complexidade, ao risco e ao valor da contratação.

Alinhamento ao planejamento, plano de contratações e proposta orçamentária

As contratações de TIC devem estar vinculadas ao planejamento de TIC, ao plano de contratações e à proposta orçamentária. Essa vinculação demonstra que a contratação decorre de prioridade definida, possui respaldo orçamentário e contribui para objetivos institucionais.

O art. 18 da Lei 14.133/2021 prevê a compatibilização da contratação com o plano de contratações anual e o planejamento da Administração. O art. 11 também reforça a responsabilidade da alta administração pela governança das contratações.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E7);
- No subitem d) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização (E8).

A ausência de alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária eleva o risco de fragmentação de despesas, contratações reativas ou insuficientemente priorizadas e uso pouco eficiente dos recursos orçamentários.

Conclusão

As fragilidades evidenciadas na fase preparatória das contratações de TIC reduzem a segurança de que a organização disponha de controles suficientes para assegurar, conforme aplicável ao caso concreto, processo formal de contratação, participação técnica da área de TIC, alinhamento ao planejamento e adequada instrução dos processos. Essas fragilidades elevam o risco de contratações insuficientemente fundamentadas, pouco rastreáveis ou desalinhadas às necessidades institucionais, à complexidade e aos riscos das soluções de TIC pretendidas.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos aspectos da fase preparatória das contratações de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis;

- **Comunicação com Recomendação** para que estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação;
- **Comunicação com Recomendação** para que integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais.

4. Plano de ação

Para facilitar o atendimento das propostas constantes da Seção 3, a Equipe de Auditoria elaborou modelo preliminar de plano de ação contendo os encaminhamentos propostos à organização. O quadro não antecipa decisão final desta Corte de Contas e poderá ser revisto após a análise dos comentários do gestor.

Cumpre registrar que, em conformidade com o art. 4º, incisos I e II, da Deliberação TCE-RJ nº 346/2024, cabe à unidade jurisdicionada avaliar a conveniência e a oportunidade de implementar as recomendações. Ressalta-se, contudo, que a eventual decisão pela não aderência deve ser motivada: o gestor deve apresentar justificativa formal que demonstre, à luz das circunstâncias do caso concreto, as razões da decisão e, quando cabível, as medidas alternativas adotadas para tratar a situação que ensejou a recomendação.

Tabela 8 - Plano de ação contendo os encaminhamentos preliminarmente propostos

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
3	institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC			
3	integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização			
4	estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes			
4	avale a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização			
4	defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
4	realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento			
4	avale o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa			
5	institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes			
5	defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados			
5	estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos			
5	formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças			
5	formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
6	formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis			
6	estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação			
6	integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais			

(Fonte: elaboração própria)

Apêndice A. Comparabilidade com o ciclo anterior (iGovTI 2023 vs. iGovTI 2026)

A estrutura de 2026 preservou a escala de 0 a 1, as categorias de resposta e as quatro faixas de maturidade empregadas em 2023, mas alterou de forma relevante a composição dos agregados e seus pesos. As principais diferenças estão sintetizadas na Tabela 9.

Tabela 9 - Principais diferenças entre as estruturas do iGovTI 2023 e do iGovTI 2026

Aspecto	iGovTI 2023	iGovTI 2026	Implicação analítica
Composição do índice final	Governança de TIC e Gestão de TIC com pesos iguais de 0,50.	Governança de TIC com peso 0,4777 e Gestão de TIC com peso 0,5223.	A gestão passou a ter participação ligeiramente superior no índice final.
Governança de TIC	Agregação hierárquica de ModeloTI, MonitorAvaliaTI e ResultadoTI.	Agregação direta de quatro práticas relativas ao modelo de gestão, monitoramento, auditoria interna e simplificação de serviços públicos.	O componente tornou-se mais direto e incorporou práticas com escopo distinto da estrutura anterior.
Gestão de TIC	Agregação de Planejamento de TIC, Pessoas e Processos de TIC; este último reunia serviços, níveis de serviço, riscos, segurança, software, projetos e contratos.	Agregação direta das seis dimensões de Gestão de TIC descritas neste relatório.	O índice passou a evidenciar separadamente seis capacidades operacionais e de segurança.
Pessoas e contratações	Pessoas e contratações de TIC integravam o cálculo da Gestão de TIC.	Não integram a árvore de cálculo do iGovTI 2026, embora continuem relevantes para o diagnóstico e para a auditoria.	Mudanças nessas matérias não explicam diretamente a variação do índice de 2026.
Serviços, software e projetos	Serviços e níveis de serviço eram agregados distintos; software e projetos integravam Processos de TIC.	Serviços foram consolidados na dimensão Gestão de Serviços de TIC; software e projetos foram reunidos na dimensão Gestão de Soluções de TIC.	A leitura deve considerar a nova delimitação conceitual dos componentes.

(Fonte: elaboração própria)

Em razão dessas alterações, a diferença entre os valores nominais de 2023 e 2026 não deve ser interpretada automaticamente como evolução ou retrocesso institucional. Uma análise temporal válida exige a harmonização das questões e dos agregados comparáveis, além da consideração de mudanças de escopo, pesos, respondentes e qualidade das evidências.

Para viabilizar a análise longitudinal, foram elaboradas estruturas ajustadas comparáveis para 2023 e 2026, com a manutenção apenas das práticas passíveis de correspondência entre os instrumentos e a aplicação de uma estrutura comum de agregação. Após a normalização das siglas e a validação das correspondências institucionais, foram identificadas 69 organizações presentes nos dois ciclos, equivalentes a 60,5% das organizações com respostas completas em 2026. A comparação individual foi apresentada somente para esse conjunto pareado.

Os resultados ajustados comparáveis têm finalidade exclusivamente analítica. Eles não substituem os índices oficiais de cada ciclo, não eliminam integralmente os efeitos de alterações de respondentes ou de contexto institucional e não constituem, isoladamente, evidência de conformidade ou de inconformidade.

Apêndice B. Ajustes nas respostas declaradas

A Equipe de Auditoria, em busca da melhor representação do cenário atual de governança e gestão de TIC, ajustou resposta(s) declarada(s) pela organização **CGE** ao questionário iGovTI 2026.

Para tanto, foram utilizadas as justificativas e evidências fornecidas pelo jurisdicionado quando do envio das respostas ao questionário. Ressalta-se que a verificação dessa documentação foi realizada nos termos dos procedimentos definidos para a fiscalização, de modo que nem todas as evidências encaminhadas foram, necessariamente, objeto de análise exaustiva pela Equipe de Auditoria.

Seguem as alterações realizadas após a avaliação das respostas e da amostra de evidências, bem como as justificativas apresentadas pela Equipe:

Tabela 10 - Relação de respostas ajustadas pela Equipe após validação

Questão	Resposta original	Resposta ajustada	Justificativa
q2204ext[A]	Sim	Não	A evidência comprova a existência de critérios de priorização baseados em urgência e impacto, com geração automática de matriz de prioridade. Entretanto, não foram apresentados documentos ou registros que estabeleçam formalmente os procedimentos de escalamento de incidentes, como níveis hierárquicos, prazos ou gatilhos para movimentação entre grupos técnicos.
q2204ext[E]	Sim	Não	Embora o tratamento operacional de incidentes de segurança esteja evidenciado por meio de registros de remediação, não há documentação comprovando os procedimentos para notificação formal de incidentes de segurança, nem as diretrizes de comunicação interna e externa exigidas. A ausência desses elementos impede a conformidade integral com o critério estabelecido.
q2403ext[B]	Sim	Não	Embora a designação seja realizada pela alta administração, não foi apresentado documento, organograma ou regimento que explicita a linha de reporte ou subordinação hierárquica direta da função de gestão de segurança da informação ao Controlador-Geral.
q2403ext[D]	Sim	Não	Não foram identificadas evidências documentais que atribuam à gestora institucional a responsabilidade pela coordenação das ações de segurança em âmbito institucional. A normativa apresentada detalha competências específicas para um 'Responsável pelo Tratamento e Resposta a Incidentes', mas não define as atribuições de coordenação para a função de gestora designada.

Questão	Resposta original	Resposta ajustada	Justificativa
q2403ext[E]	Sim	Não	A organização possui um programa de conscientização, entretanto, os documentos apresentados não vinculam explicitamente a gestora designada à coordenação ou ao fomento das ações previstas, utilizando campos genéricos de responsabilidade.
q2403ext[F]	Sim	Não	A documentação não descreve prerrogativas, autonomia, orçamento ou equipe dedicada à função de gestora de segurança da informação, limitando-se ao ato de designação nominal.
q2504ext[A]	Sim	Não	Não foram fornecidas evidências documentais de um processo formal, ferramenta de inventário ou controle centralizado de dispositivos conectados à rede. Os relatórios de teste de segurança mencionam ativos apenas no contexto de descoberta pontual para análise de vulnerabilidades.
q2504ext[B]	Sim	Não	Não foram apresentadas evidências de um processo estruturado de inventário e controle de softwares instalados nos dispositivos. As menções a softwares em relatórios de pentest referem-se a identificação por scanners durante testes de intrusão, não a uma prática de gestão de inventário organizacional.
q2504ext[D]	Sim	Não	Os relatórios de pentest indicam que a implementação de configurações seguras não é efetiva, revelando softwares desatualizados, exposição de portas desnecessárias e ausência de hardening em ativos críticos. O cenário aponta que as recomendações de segurança ainda não foram aplicadas.
q2504ext[E]	Sim	Não	Não há evidência de processo contínuo de manutenção, monitoramento e análise de logs de auditoria corporativa. Os logs citados nos documentos referem-se a dados operacionais de ferramentas de backup ou registros pontuais de testes de intrusão, insuficientes para a gestão de segurança dos ativos.
q2504ext[G]	Sim	Não	Não foram fornecidas evidências da implementação de controles de defesa contra malware, como antivírus, EDR, ou soluções de proteção contra phishing. A exposição de endereços de e-mail identificada em testes reforça a vulnerabilidade a ameaças de engenharia social.
q2504ext[H]	Sim	Não	O relatório de pentest identificou diversas portas e serviços abertos sem necessidade, indicando falta de limitação e controle sobre o acesso à rede interna. As recomendações dos testes corroboram que o controle atual é deficiente.

Questão	Resposta original	Resposta ajustada	Justificativa
q2504ext[I]	Sim	Não	A identificação de exposição de serviços críticos no perímetro, incluindo SMB, demonstra deficiência na defesa das fronteiras da rede. Não há evidência de mecanismos de proteção de borda implementados para restringir o acesso externo indevido.
q2601ext[A]	Sim	Não	Embora existam documentos de requisitos assinados que indiquem interação entre áreas, não há evidência de que representantes da área de negócio integrem a equipe de desenvolvimento ou aquisição de forma permanente, desde a concepção até a aceitação final. A evidência atual apenas demonstra a formalização de requisitos funcionais, mas não comprova a composição da equipe com a participação contínua exigida pelo critério.
q2601ext[C]	Sim	Não	Não há menção em nenhum dos documentos apresentados sobre a consideração, identificação ou gestão de requisitos de acessibilidade e usabilidade. Os documentos focam exclusivamente em aspectos de segurança da informação e requisitos funcionais de integração entre sistemas.
q2601ext[D]	Sim	Não	Os documentos fornecidos não abordam aspectos contratuais, propriedade intelectual ou cláusulas de salvaguarda de direitos autorais de software. A evidência analisada limita-se a diretrizes técnicas internas de desenvolvimento e requisitos operacionais.
q2702	Adota parcialmente.	Não adota.	A avaliação realizada indica que a organização, embora possua uma estrutura hierárquica e tenha designado funções estratégicas específicas de segurança da informação, não formalizou perfis profissionais detalhados com competências e habilidades para a totalidade das ocupações da área de tecnologia da informação. A evidência documental restringe-se a atos pontuais de designação e a um organograma que, embora apresente a estrutura, carece de descrição técnica das atribuições e requisitos para cada cargo.
q2702ext[B]	Sim	Não	A avaliação realizada aponta que não há evidências documentais que comprovem a existência de um processo formal, ciclo ou periodicidade estabelecida para a revisão das responsabilidades e atribuições das ocupações de tecnologia da informação. A atualização normativa observada decorre de alterações pontuais, não caracterizando revisão periódica programada.

Questão	Resposta original	Resposta ajustada	Justificativa
q2702ext[C]	Sim	Não	A avaliação realizada conclui que, embora existam descrições de atividades na norma, não há um perfil profissional formalizado que relacione um conjunto de competências e habilidades técnicas e comportamentais necessárias ao preenchimento das ocupações de TI, além dos requisitos de designação legal.
q2702ext[D]	Sim	Não	A avaliação realizada constata que, embora atos normativos sejam publicados no Diário Oficial, não foi evidenciado o uso de mecanismos de transparência ativa que disponibilizem de forma organizada e proativa os perfis profissionais da área de TI às partes interessadas, como em portal institucional ou seção específica de transparência.
q2703	Adota parcialmente.	Não adota.	Não há comprovação da definição do quantitativo necessário de pessoal para a área de tecnologia e segurança da informação. As evidências limitam-se a designações pontuais de servidores para funções específicas, como Gestor de Segurança da Informação e Responsável por Incidentes (Resolução CGE nº 407/2026), e a contratos de prestação de serviços de apoio à Governança de TIC, sem apresentar metodologia, estudos técnicos de dimensionamento ou definição documentada do quadro de pessoal necessário.
q2703ext[B]	Sim	Não	Não foram apresentados elementos que demonstrem a aplicação de critérios ou procedimentos técnicos para a definição do quantitativo de pessoal. Os documentos fornecidos são apenas instrumentos de gestão de contratos e atos de designação, sem qualquer evidência de metodologia de cálculo ou critério de dimensionamento técnico para a alocação de pessoal.
q2703ext[C]	Sim	Não	Não existe evidência documental que registre a definição de um quantitativo necessário de pessoal. A captura de tela exibida contém apenas a listagem de um diretório de arquivos sem conteúdo técnico legível, e os demais documentos não tratam de metas ou quantitativos de pessoal definido.
q2703ext[D]	Sim	Não	Não foi demonstrada a existência de um processo de revisão periódica do quantitativo de pessoal. Não há registros de atas, relatórios ou atos administrativos que estabeleçam ciclos de revisão ou evidenciem reavaliações do quadro de pessoal de TI.
q2704	Adota parcialmente.	Não adota.	A evidência apresentada consiste apenas em atos de designação publicados no Diário Oficial. Não foram disponibilizados os documentos que definem os perfis profissionais exigidos para os cargos, tampouco registros que comprovem a realização de um processo de seleção estruturado com base em critérios objetivos de compatibilidade.

Questão	Resposta original	Resposta ajustada	Justificativa
q2704ext[A]	Sim	Não	Não há evidências de procedimentos de verificação prévia de impedimentos legais, tais como consultas a cadastros de sanções, certidões negativas ou relatórios de idoneidade, que fundamentem a nomeação dos gestores designados.
q2704ext[B]	Sim	Não	A documentação apresentada restringe-se a atos de designação, sem demonstrar a existência de perfis profissionais documentados ou a aplicação de critérios de seleção que validem a compatibilidade entre o perfil dos designados e as atribuições das funções ocupadas.
q2704ext[D]	Sim	Não	Não foram apresentadas evidências de transparência ativa voltadas à disponibilização dos currículos dos ocupantes dos cargos de gestão. Os atos normativos publicados no Diário Oficial não contêm informações curriculares ou links para acesso a tais dados.
q2706ext[B]	Sim	Não	Embora a organização ofereça trilhas de aprendizagem e utilize o PDPI, a evidência apresentada não demonstra formalmente a existência de mecanismos institucionais de incentivo à participação. Falta a comprovação de políticas de estímulo, campanhas ou orientações ativas que encorajem os servidores a aderir às capacitações previstas.
q2801	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada é uma listagem de documentos de um processo administrativo específico no SEI, a qual demonstra apenas a execução de um caso isolado. Não foram apresentados normativos, manuais ou procedimentos internos que institucionalizem os processos de trabalho para contratações de TI na organização. A suficiência da evidência é limitada por não comprovar a existência de processos formalmente definidos para além de casos concretos.
q2801ext[A]	Sim	Não	A evidência fornecida não demonstra a estrutura do processo de trabalho de planejamento, omitindo a descrição das etapas, responsabilidades e a definição dos fluxos. A suficiência é nula para o propósito de demonstrar um processo de trabalho estruturado, pois exhibe apenas registros de documentos individuais em uma contratação única.
q2801ext[B]	Sim	Não	Embora a imagem liste documentos preenchidos em uma contratação específica, isso não comprova a disponibilização de uma biblioteca de artefatos padronizados ou modelos para uso organizacional. A evidência falha em demonstrar a existência de templates ou modelos de referência padronizados.

Questão	Resposta original	Resposta ajustada	Justificativa
q2801ext[C]	Sim	Não	A evidência não apresenta a definição do processo de trabalho para a seleção de fornecedores, limitando-se a listar documentos inseridos no SEI. Não há descrição de fluxo de trabalho ou das responsabilidades dos atores na referida fase, resultando em insuficiência documental.
q2801ext[D]	Sim	Não	Não há comprovação de modelos padronizados, minutas ou checklists para a seleção de fornecedores. A evidência contém documentos preenchidos para uma contratação específica, o que não equivale à disponibilização institucional de modelos para uso amplo.
q2801ext[E]	Sim	Não	A evidência não demonstra a definição de processos para a gestão e fiscalização contratual. Não foram identificadas descrições das etapas, responsabilidades ou fluxos de trabalho correspondentes, tornando a evidência insuficiente.
q2801ext[F]	Sim	Não	Não há artefatos padronizados visíveis para a gestão e fiscalização contratual. A evidência limita-se a documentos pontuais, sem demonstrar a existência de modelos de planos de fiscalização, relatórios ou registros de ocorrências padronizados pela organização.
q2801ext[G]	Sim	Não	Como não houve a apresentação da definição dos processos e artefatos padronizados, não é possível avaliar a conformidade normativa dos mesmos. A evidência é insuficiente para atestar a aderência às normas legais vigentes.
q2803	Adota em maior parte ou totalmente.	Não adota.	A organização não comprovou a publicidade das fases de planejamento (ETP, TR) e seleção de fornecedores (editais) das contratações de TI. Embora a planilha de contratos vigentes apresente links para extratos contratuais, essa evidência é insuficiente para cobrir o ciclo completo de transparência exigido pela norma.
q2803ext[A]	Sim	Não	Não há evidência verificável de que os ETPs das contratações de TI foram publicados no PNCP. Os documentos fornecidos são cópias internas do processo administrativo SEI, sem registro ou comprovação de divulgação no portal oficial.
q2803ext[B]	Sim	Não	Não há evidência verificável de que os Termos de Referência (TR) das contratações de TI foram publicados no PNCP. O documento fornecido é uma versão interna vinculada ao processo SEI, sem comprovação de sua divulgação no portal de compras.

Questão	Resposta original	Resposta ajustada	Justificativa
q2803ext[C]	Sim	Não	Não foram apresentados editais, avisos de contratação direta ou anexos com prova de publicação no PNCP. A evidência disponível limita-se a uma relação de contratos vigentes, a qual não supre a necessidade de comprovar o ciclo completo de seleção e publicação de instrumentos convocatórios.
q3001	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada consiste unicamente em um normativo institucional, a “Política de Inteligência Artificial”, que estabelece diretrizes e governança para a tecnologia. Não foram fornecidos registros, contratos, inventários de sistemas ou relatórios que comprovem a utilização efetiva de inteligência artificial nas operações da organização.
q3001ext[A]	Sim	Não	O documento normativo define a responsabilidade das unidades em identificar oportunidades, conforme o Art. 12. Contudo, não foram apresentadas evidências documentais, como atas de reunião, relatórios de análise ou planejamentos estratégicos, que demonstrem a execução contínua desse processo.
q3001ext[B]	Sim	Não	Embora o normativo institua um Sandbox de Inovação para avaliações experimentais (Art. 17), não há comprovação da execução de projetos-piloto ou provas de conceito. A documentação apresentada não inclui planos de testes, escopos ou relatórios conclusivos de casos reais.
q3001ext[C]	Sim	Não	A política menciona requisitos técnicos para o desenvolvimento de soluções, conforme Art. 13. Entretanto, não foram apresentadas evidências concretas de soluções desenvolvidas internamente, tais como documentação técnica, repositórios de código ou projetos específicos.
q3001ext[D]	Sim	Não	A evidência restringe-se a normas regulatórias e não identifica sistemas operacionais em ambiente de produção. Não foi demonstrada a existência de nenhuma ferramenta de inteligência artificial em uso corrente apoiando processos internos da organização.
q3001ext[E]	Sim	Não	Não foram fornecidas evidências de soluções operacionais voltadas para atividades finalísticas ou serviços ao cidadão. O documento limita-se a disciplinar o uso, sem apresentar casos práticos de aplicação finalística.

Questão	Resposta original	Resposta ajustada	Justificativa
q3003[C]	Sim	Não	A evidência apresentada é insuficiente para comprovar a contratação de serviço especializado em inteligência artificial. O Acordo de Cooperação Técnica (Processo SEI-320001/002554/2024, p. 1) trata exclusivamente de cessão não onerosa de solução tecnológica, conforme Cláusulas Primeira e Sétima. A Ordem de Serviço nº 34 (Processo SEI-320001/000406/2024, p. 2) descreve apenas serviços genéricos de TI, como manutenção, suporte e consultoria, sem qualquer vinculação explícita ou técnica a atividades relacionadas à inteligência artificial. Falta a apresentação de contrato, edital ou documento correlato que identifique expressamente a aquisição ou contratação de serviços de consultoria, desenvolvimento, treinamento ou sustentação voltados especificamente à inteligência artificial.
q2203	Adota em maior parte ou totalmente.	Não adota.	Embora a organização tenha instituído uma norma complementar para a gestão de ativos (CGE_NC_Gestao_Ativos_1.0_ST_2203.docx.pdf), não foram apresentadas evidências documentais que comprovem a efetiva operacionalização desse processo. Não há registros de inventários atualizados ou evidências de prática de gestão de configuração em funcionamento. Os demais documentos apresentados são relatórios de vulnerabilidade de aplicações, os quais não suprem a carência de evidências sobre o ciclo de vida e controle de ativos de TI.
q2203ext[A]	Sim	Não	Não foi demonstrada a existência de uma base de dados de configuração (CMDB) ou inventário equivalente que consolide as configurações e relacionamentos dos ativos de TI. Os relatórios anexados referem-se exclusivamente a análises de vulnerabilidades de segurança e não contêm informações sobre o mapeamento de configurações ou ativos tecnológicos. A ausência de um repositório centralizado impede a verificação da conformidade com o requisito de manutenção de base de dados de configuração.
q2203ext[B]	Sim	Não	Não foram fornecidos registros ou evidências que demonstrem a utilização de uma base de configurações como subsídio para o planejamento ou acompanhamento de mudanças em TI. Como a existência de uma base de dados de configurações (CMDB) não foi confirmada, sua aplicação no processo de gestão de mudanças não pôde ser validada. O material probatório restringe-se a relatórios de segurança, sem a apresentação de fluxos, atas ou ferramentas que evidenciem o processo de gestão de mudanças.

Questão	Resposta original	Resposta ajustada	Justificativa
q2701	Adota parcialmente.	Não adota.	A Equipe de Auditoria avalia que os perfis profissionais foram definidos apenas para funções específicas de segurança da informação, conforme a Resolução CGE nº 407 de 04 de maio de 2026. Embora o ato designe servidores e liste atribuições, ele não abrange a totalidade das ocupações ou grupos de gestão de TI da organização. Essa limitação demonstra que o atendimento ao critério ocorre de forma incompleta. A principal lacuna consiste na ausência de documentação de perfis para as demais ocupações de gestão de TI.
q2701ext[B]	Sim	Não	A avaliação da Equipe de Auditoria indica que a evidência apresentada descreve uma alteração normativa reativa a uma Instrução Normativa externa, e não uma revisão periódica planejada. Não foi apresentado cronograma, rotina institucional ou ato normativo que estabeleça periodicidade para a revisão das atribuições dos gestores. A lacuna consiste na ausência de evidência de um processo cíclico e controlado de revisão documental das competências.
q2705	Adota parcialmente.	Não adota.	A avaliação indica que o critério não é atendido. As evidências apresentadas, consistentes nas Resoluções nº 395 e nº 407, limitam-se à composição do Comitê de Governança de TI e à designação de servidores para funções de segurança, não configurando diagnóstico de competências. Tais atos administrativos não suprem a ausência de um processo formal de identificação e registro de lacunas. Persiste a lacuna quanto à ausência de matriz de competências, levantamento de necessidades de capacitação ou plano de desenvolvimento documentado para os colaboradores e gestores da área.
q2705ext[A]	Sim	Não	Não foram apresentadas evidências de identificação de lacunas de competências transversais. Os documentos enviados restringem-se a nomeações e composição de comitês, sem análise das habilidades comuns aos colaboradores. Identifica-se a ausência de diagnóstico ou registro documentado das lacunas de competências pessoais da organização.
q2705ext[B]	Sim	Não	A documentação apresentada não demonstra a identificação de lacunas de competências de liderança e gestão. Os atos normativos comprovam a designação de gestores para funções específicas, mas não a avaliação de seus perfis ou competências gerenciais. Falta evidência documental de diagnóstico ou mapeamento de lacunas nessa dimensão.

Questão	Resposta original	Resposta ajustada	Justificativa
q2705ext[C]	Sim	Não	Não há evidência da identificação de lacunas de competências técnicas em tecnologia da informação. A documentação limita-se à composição do comitê de governança, sem apresentar matriz ou avaliação técnica dos colaboradores. Identifica-se a ausência de diagnóstico ou levantamento de necessidades de capacitação técnica na área de TI.
q2705ext[D]	Sim	Não	A documentação apresentada refere-se à designação funcional para segurança da informação, sem contemplar a identificação de lacunas técnicas. Não foram encontrados registros de matriz de competências ou diagnóstico de necessidades de capacitação para os colaboradores da área. Persiste a lacuna documental quanto ao mapeamento de competências técnicas de segurança da informação.
q2708[A]	Sim	Não	A avaliação realizada indica que a evidência apresentada é insuficiente para comprovar a criação de cargo efetivo de tecnologia da informação. Os formulários de avaliação de desempenho enviados atestam apenas a lotação em unidade denominada 'ASSTINF', o que não equivale a ato normativo de criação de carreira ou quadro próprio de pessoal. É necessária a apresentação de documento formal, como lei ou decreto, que comprove a criação do referido cargo na estrutura da organização.
q2708[B]	Sim	Não	A avaliação realizada aponta que os documentos apresentados são insuficientes para demonstrar a atribuição formal de cargos ou funções à área de tecnologia da informação. Os formulários de avaliação de desempenho referem-se à situação funcional individual e não constituem ato formal de designação ou estruturação da área. Faz-se necessária a apresentação de norma ou ato administrativo que formalize a atribuição dessas funções à unidade.
q2802	Adota em maior parte ou totalmente.	Não adota.	A organização não comprova a execução de um processo de planejamento anual de contratações (PCA) nos termos da Lei 14.133/2021. Embora os documentos apresentados, como o PEDTIC (versão 6.0, p. 16, 33-40) e o Planejamento Tático (p. 3-8), demonstrem um processo estruturado de planejamento de Tecnologia da Informação, eles não constituem o PCA formal obrigatório. Falta a apresentação de um instrumento de planejamento que consolide as contratações da organização como um todo, conforme exige o art. 12 da referida lei.

Questão	Resposta original	Resposta ajustada	Justificativa
q2802ext[A]	Sim	Não	Não há evidência da aprovação formal de um Plano de Contratações Anual (PCA) pela alta administração da organização. Embora o documento PEDTIC (p. 2) contenha registro de aprovação pelo Controlador-Geral do Estado, tal instrumento não se confunde com o PCA exigido pela legislação vigente. A aprovação demonstrada refere-se especificamente ao planejamento de Tecnologia da Informação e não supre a necessidade de ato formal deliberativo sobre o PCA da organização.
q2802ext[B]	Sim	Não	Não foram apresentadas evidências documentais que comprovem a participação estruturada dos diversos setores da organização na elaboração de um PCA. As evidências trazem a lista de membros do Comitê Permanente do PEDTIC (p. 2 e 8 do documento PEDTIC), o que demonstra governança sobre o planejamento de tecnologia, mas não sobre o plano de contratações geral da instituição. Não há atas, registros de reuniões ou outros documentos que comprovem a consulta ou a colaboração das áreas na definição de um plano anual de contratações.
q2802ext[C]	Sim	Não	Não é possível verificar se o PCA considera os demais instrumentos de planejamento da organização, visto que o PCA não foi apresentado. O PEDTIC demonstra, nas páginas 4, 13 e 14, estar em consonância com o Plano Estratégico (PEI), o Plano Plurianual (PPA) e a Lei Orçamentária Anual (LOA), contudo, tal integração é restrita ao plano de tecnologia da informação. Inexiste evidência da articulação entre o plano de contratações e os instrumentos de planejamento institucional.
q2802ext[D]	Sim	Não	Não foi demonstrado que o planejamento de contratações sirva de fundamento para a proposta orçamentária da organização. Embora o PEDTIC apresente a tabela 'Despesas Planejadas PEDTIC - 2025' (p. 16), com previsão de gastos e alinhamento à LOA, a evidência indica que o orçamento é um insumo para o PEDTIC, e não que o planejamento de contratações preceda ou baseie a proposta orçamentária. Ausente a comprovação da relação direta entre o PCA e o fundamento da proposta da Lei Orçamentária Anual.
q2802ext[E]	Sim	Não	Não há qualquer evidência de publicação do PCA ou de suas alterações no Portal Nacional de Contratações Públicas (PNCP), descumprindo a obrigatoriedade legal estabelecida no art. 12, §1º, da Lei 14.133/2021. Os documentos fornecidos, que tratam exclusivamente de planejamento de TIC e institucional, não possuem qualquer menção a publicidade no referido portal. É necessária a apresentação de link, protocolo ou captura de tela que comprove a transparência e a publicidade oficial do plano anual de contratações.

Questão	Resposta original	Resposta ajustada	Justificativa
q2804[A]	Sim	Não	A evidência apresentada é insuficiente para comprovar a afirmação de que toda contratação de TI é obrigatoriamente submetida à análise prévia e aprovação técnica da área de gestão de TI. O Estudo Técnico Preliminar demonstra a participação de diretorias técnicas do PRODERJ apenas na estruturação de um processo de contratação específico para adequação à LGPD. O documento não apresenta norma administrativa, portaria ou regulamento de caráter geral que estabeleça essa prática como regra mandatória para o conjunto das contratações de soluções de tecnologia da informação da organização. Faz-se necessária a apresentação de instrumento formal que institucionalize a obrigatoriedade da submissão técnica para o fluxo de contratações de TI.
q1004ext[F]	Sim	Não	Os relatórios de análise de riscos apresentados restringem-se estritamente à Gestão de Riscos de Segurança da Informação, abordando ameaças como malware, indisponibilidade e vazamento de dados. Não foram identificadas evidências do uso da gestão de riscos como ferramenta para simplificação administrativa, desburocratização ou revisão crítica de controles desnecessários nos serviços públicos. Existe, portanto, uma lacuna na aplicação da gestão de riscos com o foco estabelecido pelo requisito.
q1004ext[G]	Sim	Não	A evidência fornecida não demonstra a existência ou utilização de pesquisas de satisfação dos usuários de serviços públicos para subsidiar melhorias. O planejamento apresentado refere-se, em âmbito de avaliação, apenas a pesquisas de clima organizacional voltadas ao público interno, sem contemplar o cidadão ou usuário externo do serviço público. É necessário que a organização formalize instrumentos de escuta ativa voltados ao público externo para o atendimento deste quesito.
q2503ext[C]	Sim	Não	A avaliação da Equipe de Auditoria indica que o processo de classificação de informações fornecido não abrange o sigilo fundamentado na segurança da sociedade ou do Estado. O pacote de evidências restringe-se integralmente ao tratamento de dados pessoais sob a égide da LGPD, sem contemplar os procedimentos específicos de classificação, rotulagem ou manuseio de documentos sigilosos estatais conforme exigido pela Lei de Acesso à Informação. A evidência é, portanto, insuficiente. Faz-se necessária a apresentação de política ou procedimento específico que trate de informações sigilosas de segurança pública ou de Estado.

(Fonte: elaboração própria)